KOPERASI KARYAWAN USAHA BERSAMA (KKUI)

DOKUMENTASI MASTER PROYEK

KKUI Loan Services & Member Portal — End-to-End Enterprise Specification

Nama Sistem	KKUI Loan Services & Member Portal (Aplikasi Web Anggota & Backoffice Koperasi)
Mitra Implementasi	PT Parvata Jingga (Paket Enterprise Full — 41 Kelompok Fungsi)
Product Owner & SM	Avhan HB (KKUI)
Tim Pengembang Teknis	• Fahmy (Lead Fullstack Developer) • Mike (Core & Backoffice Fullstack Developer) • Fadhi W (Cyber Security & DevSecOps Lead)
Standar Kepatuhan	OWASP ASVS v4.0 Level 2, ISO/IEC 27001:2022 ISMS, ISO/IEC 27701 (UU PDP)
Infrastruktur Target	Single Linux VPS Ubuntu 24.04 LTS (4 vCPU / 8 GB RAM / 100–150 GB NVMe / 300 Anggota)
Tanggal Baseline	7 November 2026 (Versi Kompilasi 1.0 Master)

DAFTAR ISI DOKUMEN MASTER

1. **Bagian 1:** SDLC Agile & Tata Kelola SOW Parvata Jingga (Matriks Tanggung Jawab & SLA)
2. **Bagian 2:** Product Requirement Document (PRD v1.2 — Spesifikasi 41 Kelompok Fungsi)
3. **Bagian 3:** Spesifikasi Arsitektur Teknis, ERD Database PostgreSQL & Kontrak RESTful API
4. **Bagian 4:** Blueprint Keamanan Sistem, Threat Modeling STRIDE & Playbook Hardening VPS
5. **Bagian 5:** Master Test Plan, Metodologi Security Pentest & Panduan UAT Sign-Off Form
6. **Bagian 6:** Rencana Eksekusi Harian Sprint 1 (Task Breakdown 9–20 November 2026)
7. **Bagian 7:** SOP Operasional Server, Backup Disaster Recovery & Panduan Administrasi Backoffice

BAGIAN 1: SDLC AGILE & SOW GOVERNANCE

SDLC Agile - KKUI Loan Services & Member Portal (Compliance OWASP ASVS & ISO 27001)

Nov 7, 2026 · Product & Engineering KKUI & PT Parvata Jingga

Informasi Proyek

Isi tabel ini di awal proyek; bagian lain di dokumen ini merujuk ke data di sini.

Item	Isian
Nama proyek	KKUI Loan Services & Member Portal (Aplikasi Web Anggota & Backoffice Koperasi)
Mitra Implementasi	PT Parvata Jingga (Paket Enterprise Full - Total Scope ±41 Kelompok Fungsi)
Product Owner	Avhan HB
Scrum Master	Avhan HB (Dual-hatting Product Owner & Scrum Master)
Tim Pengembang	**Total 3 Orang (Dedicated Technical Team):** • Senior Fullstack Developer (Lead Dev): **Fahmy** • Mid/Senior Fullstack Developer: **Mike** • Cyber Security & DevSecOps Engineer: **Fadhi W**
Tech Stack & Infrastruktur	**Frontend Web & Mobile Responsive:** React / Next.js, Tailwind CSS (KKUI Design System - Inter, Deep Emerald Green `#003527`, Mint Accent `#31c98f`) **Backend & API:** Node.js RESTful API, EOD Cron Batch Engine **Database & Cache:** PostgreSQL (Core Transactional), Redis (Session, Rate Limiting & Queue Background Job) **Autentikasi Mandiri & Keamanan:** Native Argon2id Password Hashing, MFA TOTP (RFC 6238), Rate Limiter, CAPTCHA, Server-side RBAC Engine **Infrastruktur Production:** Single Linux VPS Ubuntu 24.04 LTS (4 vCPU, 8 GB RAM, 100-150 GB NVMe, Nginx Reverse Proxy + SSL/TLS, UFW Firewall, SSH Key-only, Offsite Backup harian retensi 14-30 hari) berkapasitas 300 anggota (30-60 concurrent users) **Integrasi Pihak Ketiga:** Mesin Scoring Kredit Mandiri (Internal SLIK Engine), PrivyID/Peruri (e-Sign Digital Akad), Midtrans/Xendit (Payment Gateway VA), API Bank Cash Disbursement, HR System (Payroll PR23 Auto-Sync), WhatsApp Gateway (Notifikasi & Surat Peringatan) **DevOps & SecOps:** Docker, GitHub Actions CI/CD (Semgrep SAST, Trivy Container Vulnerability Scan, OWASP ZAP DAST Baseline Scan, WAF & Cloud Armor)
Standar Kepatuhan	**OWASP Top 10 (2021) & OWASP ASVS v4.0** (Level 2 - Standard Financial Applications) **ISO/IEC 27001:2022** (Information Security Management System - ISMS Controls A.5, A.6, A.8) **ISO/IEC 27701:2019** (Privacy Information Management - PIMS / Kepatuhan UU Pelindungan Data Pribadi)
Tanggal Mulai	7 November 2026
Panjang Sprint	2 minggu (Total 6 Sprint operasional / 12 minggu pengembangan aktif + fase discovery & hardening = 15-21 minggu sesuai SOW Parvata Jingga)
Alat Bantu	Jira, GitHub Projects & Git, Figma / Stitch UI Portal Workspace, Slack / MS Teams

Visi Produk dan Tujuan

Visi satu kalimat menjadi acuan setiap keputusan prioritas di backlog.

Pernyataan visi: Untuk anggota koperasi karyawan dan debitur internal yang membutuhkan akses pembiayaan dan pengelolaan simpanan yang cepat, transparan, dan berstandar keamanan tinggi, **KKUI Loan Services Portal** adalah aplikasi web keuangan koperasi mandiri (mencakup ±31 submodul front-office simpanan & pinjaman serta ±10 submodul backoffice operasional) yang memfasilitasi pengajuan kredit mandiri (Kredit Barang & Jasa, Dana Tunai, UMKM), verifikasi dokumen keanggotaan internal, otomasi SLIK, integrasi pemotongan payroll PR23, hingga pencairan instan, berbeda dari sistem koperasi konvensional karena dibangun oleh tim ramping berkeahlian tinggi (*two fullstack engineers + one cyber security engineer*) di bawah kepemimpinan Product Owner **Avhan HB** di atas arsitektur keamanan mandiri (*native auth & MFA*, tanpa ketergantungan e-KYC/SSO eksternal) pada infrastruktur Linux VPS teroptimasi yang patuh penuh terhadap **OWASP ASVS** dan **ISO/IEC 27001**.

Tujuan	Ukuran keberhasilan	Target	Tenggat
Otomasi & Akselerasi SLA Pinjaman	Rata-rata waktu persetujuan pengajuan pinjaman (*Turnaround Time / SLA*) dari verifikasi internal hingga pencairan	< 24 jam untuk jalur hijau (payroll PR23 / risiko rendah)	Akhir Sprint 6 (Rilis 2)
Verifikasi Keanggotaan Internal	SLA verifikasi berkas pendaftaran manual anggota (KTP, Slip Gaji, ID Karyawan) oleh Admin Frontdesk	100% berkas diproses dalam rentang waktu ≤ 24 jam	Akhir Sprint 3 (Rilis 1 MVP)
Kepatuhan OWASP & Nol Celah Keamanan	Hasil pengujian kerentanan (*Penetration Testing* & DAST/SAST) berbasis OWASP Top 10	Nol celah keamanan *Critical* dan *High*; 100% lolos verifikasi ASVS Level 2	Pra-Rilis Production (Sprint 3 & 6)
Kepatuhan ISO/IEC 27001 (ISMS & Audit Trail)	Integritas pencatatan log audit transaksi keuangan, enkripsi data at-rest (AES-256) & in-transit (TLS 1.3), serta tata kelola hak akses berbasis *Least Privilege*	100% aktivitas transaksi dan *credential maintenance* tercatat di *Immutable Audit Log* tanpa celah manipulasi	Akhir Sprint 3 (Rilis 1 MVP)
Ketersediaan & Keandalan VPS 300 Anggota	Target ketersediaan sistem (*availability*) pada Linux VPS (4 vCPU / 8 GB RAM) untuk 300 anggota aktif	Availability target ≥ 99,5%; penggunaan CPU/RAM rata-rata < 70%	Operasional Go-Live & Garansi 90 Hari
Efisiensi Operasional Treasury & Payroll	Tingkat rekonsiliasi otomatis pemotongan gaji (PR23) dan settlement Payment Gateway VA	100% rekonsiliasi harian otomatis tanpa selisih manual	Akhir Sprint 6 (Rilis 2)

Peran Tim & Governance (Developer vs User Matrix)

Dengan komposisi tim ramping (3 orang teknis + 1 PO/Scrum Master) dan pembagian tanggung jawab mengacu pada *SOW & Responsibility Matrix Parvata Jingga*, pembagian peran dioptimalkan untuk menjaga prinsip *Segregation of Duties* (ISO 27001 Control A.6.1.2).

Peran	Tanggung jawab utama	Nama / Alokasi
Product Owner & Scrum Master	Mengelola product backlog, menetapkan prioritas bisnis simpan pinjam, memfasilitasi ceremony Agile, menyingkirkan hambatan, menyediakan aturan bisnis & formula denda/bunga, menerima atau menolak hasil sprint	**Avhan HB**
Fullstack Developer 1 (Lead Fullstack)	Memimpin arsitektur aplikasi (React frontend & Node.js API), implementasi antarmuka portal anggota (e-Katalog, simulasi pinjaman, dashboard simpanan), API core kredit, dan integrasi frontend-backend	**Fahmy**
Fullstack Developer 2	Membangun portal Backoffice (LOS Approval Center, Member 360, Treasury Disbursement, CMS), batch processing EOD/NPL, skema PostgreSQL, dan integrasi API pihak ketiga (SLIK, Payment Gateway, e-Sign)	**Mike**
Cyber Security & DevSecOps Engineer	Bertanggung jawab penuh atas arsitektur keamanan (Threat Modeling, Hardening Native Auth Argon2id & MFA TOTP), setup WAF & Nginx TLS, pipeline CI/CD SAST/DAST, audit logging ISO 27001, vulnerability assessment & penetration testing (VA/PT)	**Fadhi W**
Stakeholder & Business Management	Memberi masukan operasional koperasi, memvalidasi kepatuhan tata kelola risiko, audit keuangan berkala (Ketua Koperasi, Manajer Operasional, Bendahara Treasury, Admin Frontdesk)	Tim Manajemen KKUI

Matriks Tanggung Jawab & SLA Tata Kelola (SOW Governance)

Tahap / Area	Tanggung Jawab Developer (Fahmy, Mike, Fadhi W)	Tanggung Jawab User / PO (Avhan HB / KKUI)	Output & Kriteria Penerimaan	SLA
1. Requirement & Scope	Workshop, analisis proses bisnis, backlog, estimasi, arsitektur, dan batasan teknis	Menunjuk PIC, menjelaskan proses, menyediakan requirement, contoh dokumen, dan aturan bisnis	BRD, backlog, flow, dan scope baseline disetujui	3 hari kerja
2. UI/UX & Design	Implementasi desain responsif, design system KKUI, prototipe teknis, dan revisi	Memvalidasi konten, wording, alur, branding, dan memberikan persetujuan desain	UI/UX sign-off sebelum development penuh	3 hari kerja
3. Development	Membangun React frontend, Node.js API, PostgreSQL, Backoffice, RBAC, dan audit trail	Menyediakan master data, formula, role, approval authority, dan akses integrasi	Demo per sprint dan fitur sesuai acceptance criteria	2 minggu / sprint
4. Environment & Security	Setup Linux VPS, Nginx, TLS, WAF, hardening, backup, logging, dan security scan	Menyediakan akun/domain, akses DNS, biaya recurring VPS, kebijakan sandi, dan PIC keamanan	Environment aktif, checklist security, dan bukti konfigurasi	Sesuai jadwal rilis

Tahap / Area	Tanggung Jawab Developer (Fahmy, Mike, Fadhi W)	Tanggung Jawab User / PO (Avhan HB / KKUI)	Output & Kriteria Penerimaan	SLA
5. Testing & UAT	Unit/integration test, test evidence, dukungan UAT, dan perbaikan defect	Menyiapkan user tester, skenario bisnis, data uji, dan keputusan pass/fail	UAT sign-off; defect kritis/high ditutup sebelum go-live	5 hari kerja
6. Deployment & Handover	Deploy release, migrasi awal, dokumentasi, training admin, dan source-code handover	Menyetujui jadwal go-live, menyediakan data final, menerima training dan dokumen	Go-live checklist, admin guide, source code, dan berita acara serah terima	2–3 hari kerja
7. Warranty & Change	Memperbaiki bug dalam scope selama 90 hari garansi; mencatat dan mengestimasi change request	Melaporkan bug dengan bukti jelas; menyetujui biaya/timeline untuk scope tambahan	Bug log, closure evidence, CR/quotation bila di luar scope	Critical bug ≤ 1 hari

Standar Keamanan & Kepatuhan Arsitektur (Defense-in-Depth)

Mengacu pada arsitektur proteksi berlapis (*Defense-in-Depth*) Parvata Jingga, standar keamanan diawasi langsung oleh **Fadhi W** (*Cyber Security Engineer*) pada setiap lini:

1. Kepatuhan OWASP (ASVS Level 2 & OWASP Top 10)

- **V1 Architecture, Design and Threat Modeling:** Pemodelan ancaman (*threat modeling*) dilakukan pada setiap fitur finansial; tidak mengandalkan SSO pihak ketiga dan tidak memakai layanan vendor e-KYC luar untuk menjaga kedaulatan data anggota.
- **V2 Authentication & Password Security:** Penyimpanan sandi menggunakan algoritma adaptif *Argon2id* dengan *salt* unik kriptografis; kebijakan sandi kuat (minimal 12 karakter, kombinasi huruf besar, kecil, angka, dan simbol); perlindungan *anti-brute force* (penguncian akun sementara setelah 3 kali gagal berturut-turut + tantangan CAPTCHA).
- **V3 Session Management:** Session token berbasis HTTP-only, Secure, SameSite=Strict cookies; masa kedaluwarsa sesi idle 15 menit; regenerasi Session ID saat login dan perubahan hak akses; proteksi Session Hijacking dan Fixation.
- **V4 Access Control (RBAC):** Penegakan otorisasi di sisi backend (*server-side authorization*) dengan prinsip *Deny by Default*; pencegahan IDOR (*Insecure Direct Object Reference*) menggunakan UUIDv4 acak dan validasi kepemilikan data CIF/rekening.
- **V5 Input Validation & Sanitization:** Validasi ketat format input di server (whitelist validation); penanganan encoding untuk mencegah XSS (*Cross-Site Scripting*); parameterized query / ORM aman untuk memitigasi SQL Injection 100%.
- **V8 Cryptography at Rest and in Transit:** Seluruh komunikasi transit wajib menggunakan TLS 1.3 (HTTPS) dengan Nginx security headers (HSTS, CSP, X-Frame-Options); data sensitif pada database (NIK, slip gaji, data rekening bank) dienkripsi menggunakan AES-256-GCM (*Cryptographic Storage*).

2. Kepatuhan ISO/IEC 27001:2022 (Kontrol ISMS) & Arsitektur VPS

- **A.5.15 Access Control & A.6.1.2 Segregation of Duties:** Pemisahan wewenang mutlak antara pembuat permohonan kredit (Anggota), pemeriksa awal (Admin Frontdesk), penyetuju kredit (Manajer), dan pengeksekusi pencairan kas (Bendahara/Ketua). Di sisi tim engineering, kode fitur dikembangkan oleh **Fahmy** & **Mike**, dan wajib di-review keamanannya oleh **Fadhi W** sebelum merge ke branch production.
- **A.8.12 Data Leakage Prevention & A.8.24 Use of Cryptography:** Perlindungan berkas unggahan manual anggota (KTP, kartu pegawai, slip gaji) dalam storage terenkripsi privat tanpa akses URL publik; akses berkas dibatasi presigned URL bertenggat waktu 5 menit.
- **A.8.15 Logging and Monitoring:** Implementasi *Immutable Audit Trail* (WORM - Write Once Read Many) yang mencatat *who, what, when, where, and result* (termasuk upaya login gagal, modifikasi data profil, persetujuan pinjaman, dan eksekusi treasury) tanpa mencatat data rahasia seperti plain password atau PIN.
- **Linux VPS Production Hardening:** UFW Firewall (hanya port 80/443 dan custom port SSH aktif), akses SSH Key-only (menonaktifkan password authentication dan root login), Fail2ban untuk proteksi brute-force SSH, serta backup offsite database otomatis harian dengan retensi 14-30 hari.

Product Backlog (Cakupan 41 Kelompok Fungsi)

Setiap kebutuhan ditulis sebagai user story dan diurutkan dari prioritas tertinggi di paling atas, mencakup 31 submodul front-office dan 10 submodul backoffice.

Format user story: Sebagai [peran pengguna], saya ingin [aksi], agar [manfaat].

ID	User story	Acceptance criteria	Prioritas	Estimasi (story point)	Sprint
US-01	Sebagai calon anggota, saya ingin mendaftar akun menggunakan email internal/pribadi dengan verifikasi OTP email serta upload dokumen KTP dan kartu pegawai secara mandiri, agar terdaftar dengan identitas valid tanpa e-KYC pihak ketiga	Form pendaftaran memvalidasi format email & password kuat (OWASP V2); OTP 6 digit terkirim via email bertenggat 5 menit; upload KTP & ID Karyawan divalidasi MIME type dan scan antivirus/malware; status akun berstatus 'Pending Verification' menunggu approval Admin Frontdesk	Tinggi	5	Sprint 1
US-02	Sebagai staf/admin backoffice, saya ingin login menggunakan kredensial email & password mandiri yang diproteksi MFA Authenticator (TOTP RFC 6238) dan RBAC engine, agar portal terlindungi secara native tanpa SSO eksternal	Autentikasi native dengan hash Argon2id; proteksi brute-force (kunci akun 15 menit jika salah ≥3 kali berturut-turut + CAPTCHA); verifikasi wajib TOTP 2FA; RBAC engine membatasi akses menu sesuai role (Admin Frontdesk, Manajer, Bendahara, Ketua, IT Security); pencatatan audit log login (IP, timestamp, user agent) sesuai ISO 27001	Tinggi	5	Sprint 1
US-03	Sebagai Admin Frontdesk & Manajer Operasional, saya ingin mereview antrean pendaftaran anggota dengan verifikasi manual dokumen serta screening AML/PEP internal, agar anggota baru divalidasi secara patuh hukum	Antrean menampilkan berkas KTP dan Kartu Pegawai terenkripsi via secure temporary viewer; pengecekan nama pada database internal AML/PEP watchlist (Clear / Flagged); alur persetujuan bertingkat (Admin, Manajer, Bendahara); auto-generate nomor CIF dan akun simpanan setelah approved	Tinggi	5	Sprint 1
US-04	Sebagai anggota, saya ingin melihat ringkasan portofolio simpanan (Pokok, Iuran Wajib, Sukarela, SISKA) dan mengunduh e-Sertifikat keanggotaan, agar mengetahui posisi saldo keuangan saya	Dashboard menampilkan kartu saldo real-time per jenis simpanan; tombol unduh e-Sertifikat Keanggotaan PDF ber-watermark dinamis dan hash integritas; tabel mutasi transaksi dengan filter tanggal dan fitur export laporan	Sedang	3	Sprint 2
US-05	Sebagai anggota, saya ingin mengajukan Kredit Barang & Jasa dari e-Katalog terintegrasi pengecekan scoring kredit internal dan rasio utang internal, agar bisa mencicil kebutuhan barang secara transparan	e-Katalog menampilkan daftar produk dan simulasi tenor; sistem otomatis mengalkulasi rasio cicilan terhadap gaji; verifikasi mesin scoring kredit internal; jika rasio utang aman (<33%), masuk form standar; jika berisiko, diarahkan ke penyesuaian DP atau potong saldo sukarela	Tinggi	8	Sprint 2
US-06	Sebagai manajer & komite pembiayaan, saya ingin mereview pengajuan kredit di LOS Approval Center dengan pemantauan batas waktu SLA dan kontrol pemisahan wewenang (Segregation of Duties), agar keputusan kredit objektif dan akuntabel	SLA task inbox menampilkan status (Aman, Menjelang Jatuh Tempo, Overdue Eskalasi); tab data rasio hutang dan skor kredit internal; panel aksi (Approve, Reject, Revise, Adjustment Tenor/Plafon); riwayat keputusan tersimpan di audit trail tanpa bisa diedit/dihapus	Tinggi	5	Sprint 2
US-07	Sebagai debitur yang disetujui, saya ingin menandatangani akad perjanjian kredit digital secara e-Sign tersertifikasi, agar pinjaman sah secara hukum sebelum pencairan	Dokumen perjanjian PDF terbit otomatis dengan data pembiayaan lengkap dan klausul fidusia/koperasi; integrasi penandatanganan digital e-Sign tersertifikasi; notifikasi reminder jika belum TTD; status tiket otomatis berpindah ke antrean Treasury setelah e-Sign valid	Tinggi	5	Sprint 3
US-08	Sebagai Bendahara Treasury, saya ingin mengeksekusi pencairan dana pinjaman via automated Bank Disbursement API dengan verifikasi saldo buffer dan batas otorisasi limit (Dual Control), agar dana cair aman ke rekening anggota	Antrean disbursement menampilkan tiket lolos e-Sign; verifikasi saldo buffer rekening penampung; validasi limit otorisasi pencairan (wajib dual authorization/token persetujuan Ketua jika melebihi plafon limit); auto-update Buku Besar (GL) dan saldo CIF	Tinggi	5	Sprint 3
US-09	Sebagai anggota, saya ingin mengajukan Pinjaman Dana Tunai (baru, top up, atau restrukturisasi cicilan) yang diamankan konfirmasi PIN 2FA, agar transaksi pinjaman tunai terlindungi dari penyalahgunaan	Verifikasi PIN transaksi 6 digit (hashing SHA-256 + salt); opsi pilih layanan: pinjaman baru / top up / restrukturisasi penurunan cicilan atau pelunasan sebagian; simulasi plafon dan kalkulator amortisasi; pencegahan race condition saat submit pengajuan	Tinggi	8	Sprint 4

ID	User story	Acceptance criteria	Prioritas	Estimasi (story point)	Sprint
US-10	Sebagai pelaku usaha mikro (anggota UMKM), saya ingin mengajukan Pinjaman UMKM dengan mitigasi 3 jalur kelayakan (Payroll PR23, Saldo Sukarela, Payment Gateway), agar memperoleh modal usaha sesuai kapasitas finansial	Input profil dan legalitas usaha; kalkulasi kelayakan otomatis: Rasio <33% (Jalur PR23 Payroll), Rasio 33%-50% (Jalur Auto-Debet Saldo Sukarela), Rasio >50% (Jalur Payment Gateway); alur penandatanganan akad e-Sign dan penerbitan VA/tagihan terjadwal	Tinggi	8	Sprint 4
US-11	Sebagai Bendahara Treasury, saya ingin mengunggah file hasil potongan gaji HRD dan menjalankan mesin auto-rekonsiliasi PR23, agar pembayaran cicilan ter-update akurat tanpa selisih	Fitur unduh file cut-off tagihan bulanan (Excel/CSV); fitur upload balikan file payroll HRD dengan validasi integritas hash (checksum SHA-256); auto-matching tagihan vs potongan riil; otomatis mencatat tunggakan (*arrears*) jika pemotongan gagal/kurang	Tinggi	5	Sprint 5
US-12	Sebagai anggota dan admin, saya ingin modul Simpanan SISKA Berjangka memiliki sistem EOD otomatis untuk perpanjangan ARO serta kalkulator penalti penarikan sebelum jatuh tempo, agar tata kelola deposito patuh aturan	Registrasi SISKA menerbitkan e-Bilyet deposito digital terverifikasi; batch EOD mengeksekusi perpanjangan otomatis (ARO); pengajuan pencairan awal otomatis menghitung penalti closing dan memotong penalti sebelum transfer pencairan	Sedang	5	Sprint 5
US-13	Sebagai Pengurus Eksekutif & Tim Kepatuhan, saya ingin mengakses Dashboard Business Intelligence (NPL, Arus Kas, Laba Rugi, Export RAT) dan Log Audit ISO 27001, agar kepatuhan dan kesehatan keuangan koperasi terpantau	Agregasi data dari Data Warehouse; visualisasi tingkat NPL per kolektibilitas (Lancar s/d Macet); kalkulasi denda otomatis EOD; viewer audit log untuk keperluan audit kepatuhan; ekspor laporan keuangan format RAT & Pajak	Sedang	5	Sprint 6
US-14	Sebagai Admin Komunikasi, saya ingin mengelola CMS artikel, banner promosi, dan broadcast notifikasi WhatsApp/push notification, agar anggota mendapatkan pembaruan informasi koperasi	CRUD artikel dan banner e-katalog; modul broadcast pesan massal WhatsApp / push notification; sanitasi input HTML untuk mencegah XSS; log pengiriman notifikasi	Rendah	3	Sprint 6

Aturan penulisan:

- Satu story harus bisa selesai dalam satu sprint; bila lebih besar, pecah.
- Acceptance criteria bisa diuji dengan jawaban ya atau tidak dan wajib mencakup aspek fungsional serta kriteria keamanan OWASP terkait.
- Skala estimasi: deret Fibonacci (1, 2, 3, 5, 8, 13); story di atas 8 wajib dipecah.
- Setiap pengajuan pinjaman wajib menyertakan validasi *server-side* anti-manipulasi data dan logging audit ISO 27001.

Definition of Ready dan Definition of Done

Definition of Ready menentukan kapan story boleh masuk sprint; Definition of Done menentukan kapan story dianggap selesai.

Definition of Ready (story siap dikerjakan)

- [ ] User story mengikuti format Sebagai-Ingin-Agar dengan narasi yang jelas
- [ ] Acceptance criteria spesifik, tidak ambigu, dan memiliki skenario pengujian positif, negatif, serta skenario keamanan (Security Test Cases)
- [ ] Estimasi story point sudah disepakati bersama oleh Tim Pengembang (Fahmy, Mike, Fadhi W)
- [ ] Desain UI (Figma / Stitch UI Portal) dan spesifikasi interaksi sudah siap dan disetujui PO (Avhan HB)
- [ ] Kontrak API (OpenAPI/Swagger schema, format payload, endpoint, kode error HTTP standar) telah didefinisikan
- [ ] Tidak mengandalkan pihak ketiga untuk e-KYC atau SSO eksternal; skema native auth dan verifikasi berkas internal telah disiapkan
- [ ] Ketergantungan eksternal yang diizinkan (Modul Scoring Kredit Internal, Payment Gateway VA, Disbursement Bank, e-Sign) sudah terverifikasi di sandbox
- [ ] Analisis dampak keamanan (*Security Threat Modeling*) singkat telah divalidasi oleh Fadhi W
- [ ] Ukuran story muat dalam satu sprint sesuai kapasitas tim (maksimal 8 story points)

Definition of Done (story selesai)

- [ ] Kode implementasi selesai dan sudah di-merge ke branch utama via Pull Request
- [ ] Peer code review disetujui oleh sesama Fullstack Developer (Fahmy / Mike)

- [ ] Security code review & security sign-off disetujui oleh Cyber Security Engineer (Fadhi W)
- [ ] Lolos pengujian keamanan SAST otomatis (Semgrep/Trivy) pada CI pipeline tanpa temuan *Critical* atau *High*
- [ ] Memenuhi standar OWASP ASVS Level 2 (validasi input server-side, proteksi IDOR, parameterized query anti-SQLi)
- [ ] Unit test dan integration test lulus dengan code coverage minimal 80% (ditulis langsung oleh Fahmy & Mike)
- [ ] Seluruh acceptance criteria lolos verifikasi manual dan pengujian regresi
- [ ] Tidak ada bug kritis (Blocker/Critical) atau kerentanan keamanan yang masih berstatus Open
- [ ] Berjalan stabil di lingkungan staging Linux VPS dan terverifikasi di multi-browser
- [ ] Seluruh operasi create/update/delete data finansial dan otentikasi terekam pada Immutable Audit Log (ISO 27001)
- [ ] Dokumentasi teknis dan API Swagger/Postman diperbarui
- [ ] Didemokan dan disetujui oleh Product Owner (Avhan HB) pada Sprint Review

Roadmap dan Perencanaan Rilis

Roadmap memetakan fitur utama ke rilis dan sprint dengan audit keamanan formal di akhir setiap rilis (total 15-21 minggu end-to-end sesuai SOW Parvata Jingga).

Rilis	Sprint	Fitur utama	Tujuan rilis & Target Kepatuhan	Target tanggal
Rilis 1 (MVP - Core Native Auth, Verifikasi Berkas & Kredit BJ)	Sprint 1-3	Modul Native Auth & 2FA TOTP, RBAC Backoffice, Pendaftaran Anggota & Verifikasi Berkas Internal + AML Screening, Member Dashboard Simpanan, Modul Kredit Barang & Jasa (e-Katalog, SLIK, Debt Ratio), LOS Approval SLA Center, e-Sign Akad Digital, Automated Bank Disbursement API	Meluncurkan fondasi mandiri koperasi yang aman tanpa dependensi SSO/e-KYC vendor; audit keamanan tahap 1 (Penetration Test internal oleh Fadhi W & verifikasi ISO 27001 Access Control)	19 Desember 2026
Rilis 2 (Layanan Pinjaman Lanjutan & Treasury Sync)	Sprint 4-6	Pinjaman Dana Tunai (Baru, Top Up, Restrukturisasi), Pinjaman UMKM 3 Jalur Risiko (PR23, Saldo Sukarela, PG), Otomasi Payroll PR23 Sync HRD & Rekonsiliasi VA Midtrans, Modul Simpanan SISKA Berjangka (ARO & Penalti), EOD NPL Collector & Notif WhatsApp, Executive BI Reporting & RAT Export	Menyelesaikan seluruh spektrum pembiayaan (Dana Tunai & UMKM), otomasi rekonsiliasi payroll, pencegahan NPL, dan pemenuhan audit kepatuhan ISO 27001	30 Januari 2027
Rilis 3 (Ekspansi & Peningkatan Layanan)	Sprint 7-9	Simpanan SMS & Pendidikan, CMS Katalog & Artikel, Sistem Poin Loyalitas Anggota, Integrasi WhatsApp Bot Interaktif Mandiri, Advanced Fraud Anomaly Detection	Memperluas produk tabungan tematik anggota dan meningkatkan otomatisasi layanan nasabah berstandar enterprise	13 Maret 2027

Sprint Planning

Bagian ini memuat perencanaan Sprint 1 yang disesuaikan dengan kapasitas tim 3 orang teknis (Fahmy, Mike, Fadhi W) dan PO/Scrum Master (Avhan HB).

Item	Isian
Sprint ke-	1
Periode	9 November 2026 sampai 20 November 2026
Sprint goal	Membangun pondasi keamanan native (Argon2id & MFA TOTP), RBAC Backoffice yang aman, pendaftaran mandiri dengan upload berkas terenkripsi, antrean verifikasi KYC internal dengan AML screening, dan setup automated DevSecOps CI/CD pipeline pada Linux VPS
Kapasitas tim	**3 Orang Pengembang:** 2 Fullstack Developers (Fahmy & Mike: 2 x 10 hari = 20 hari kerja = ~160 jam) + 1 Cyber Security Engineer (Fadhi W: 1 x 10 hari = 10 hari kerja = ~80 jam fokus secops/hardening). Total kapasitas efektif ~15 Story Points untuk story fungsional
Velocity sprint sebelumnya	0 (Sprint perdana)
Total story point terpilih	15 Story Points (US-01: 5 SP, US-02: 5 SP, US-03: 5 SP)

Sprint backlog (Sprint 1)

ID	Tugas	Penanggung jawab	Estimasi (jam)	Status
US-01	Desain skema DB master member, CIF, dan tabel verifikasi berkas anggota dengan enkripsi kolom NIK (AES-256)	Fahmy	8	To Do
US-01	Pembuatan service upload dokumen (KTP, Slip Gaji, ID Card) ke storage privat terenkripsi + validasi MIME type & sanitasi nama file	Mike	12	To Do
US-01	Pembuatan antarmuka Register anggota (Next.js/React), input data, OTP email token generator, dan upload berkas	Fahmy	14	To Do
US-01	Security review & penetration testing alur registrasi (pengujian brute-force OTP, tampering data, upload file jahat/webshell)	Fadhi W	10	To Do
US-02	Implementasi native authentication engine (Argon2id password hashing, proteksi brute-force login lock 3x, CAPTCHA)	Mike	14	To Do
US-02	Integrasi MFA berbasis Time-based One-Time Password (TOTP RFC 6238) dengan QR code enrollment & emergency backup codes	Fahmy	12	To Do
US-02	Implementasi RBAC middleware, penegakan prinsip *Least Privilege*, dan logging audit trail ke tabel append-only	Mike	10	To Do
US-02	Pembuatan UI Login Backoffice, antarmuka input MFA TOTP, dan dynamic role sidebar	Fahmy	12	To Do
US-03	Pembuatan endpoint antrean verifikasi KYC internal dan integrasi pengecekan database AML/PEP internal	Mike	12	To Do
US-03	Pembuatan UI Backoffice KYC Reviewer (secure temporary image viewer dengan presigned URL 5 menit, tombol aksi approve/reject berkas)	Mike	14	To Do
US-03	Mekanisme auto-generate Nomor CIF dan akun rekening simpanan pasca persetujuan beruntun (Admin Frontdesk & Manajer)	Fahmy	8	To Do
US-Sec	Setup Linux VPS Ubuntu 24.04 (Nginx, UFW, TLS 1.3, Fail2ban) dan CI/CD pipeline GitHub Actions dengan integrasi SAST (Semgrep), Trivy, dan OWASP ZAP	Fadhi W	16	To Do

Status yang dipakai: To Do, In Progress, In Review, Testing, Done.

Tahapan SDLC di Dalam Sprint (Secure SDLC - SSDLC)

Dengan tim 3 orang teknis, alur SSDLC dirancang kolaboratif di mana **Fadhi W** bertindak sebagai quality & security gatekeeper independen dan **Avhan HB** bertindak sebagai validator bisnis.

```
 [1. Analisis Kebutuhan & Threat Modeling OWASP] (Avhan HB, Fahmy, Mike, Fadhi W)
                          ↓
[2. Desain Antarmuka, Skema DB Terenkripsi, & Kontrak API] (Fahmy & Mike)
                          ↓
[3. Development: Secure Coding & Unit Testing] (Fahmy & Mike)
                          ↓
[4. Security & Quality Gate] ──(Gagal: Kembali ke Dev)──┐
   • Automated SAST/DAST (GitHub Actions)               |
   • Peer Code Review (Fahmy & Mike)                    |
   • Security Review & DAST Testing (Fadhi W)           |
                          ↓ (Lulus)                     |
[5. Deployment Staging, Audit Trail Check, Demo Sprint Review] (Fadhi W & Tim)
                          ↓                             |
[Persetujuan PO & Rilis Production dengan Gate ISO 27001] (Avhan HB) <──────┘
```

Tahap	Kegiatan	Output
Analisis	Memperjelas acceptance criteria, validasi alur diagram proses, verifikasi batas SLA, dan identifikasi risiko keamanan (*Threat Modeling* berbasis OWASP Top 10)	Story memenuhi Definition of Ready + checklist keamanan
Desain	Menyusun komponen UI (Design System KKUI), skema database PostgreSQL dengan enkripsi kolom sensitif, dan kontrak OpenAPI/Swagger berstandar OWASP	Mockup UI disetujui, spesifikasi API & skema keamanan terdokumentasi
Development	Menulis kode fullstack (React frontend & Node.js API), implementasi RBAC server-side, commit berkala di branch fitur (`feature/US-xx`), penulisan unit test mandiri	Pull Request lolos unit test & coverage ≥ 80%

Tahap	Kegiatan	Output
Pengujian & Security Gate	Automated SAST (Semgrep) & DAST (OWASP ZAP) pada CI/CD, peer review antar developer (Fahmy/Mike), pengujian penetrasi oleh Fadhi W, verifikasi audit trail ISO 27001	Test report + Security Sign-Off (Zero Critical/High Vulnerabilities)
Deployment	Merge branch ke `staging` Linux VPS, verifikasi konfigurasi server (TLS 1.3, CSP header, HSTS, WAF), demo fungsional saat Sprint Review, rilis ke production setelah verifikasi Avhan HB	Fitur aktif di production dengan audit logging aktif

Ritme Sprint dan Ceremony

Lima ceremony berulang di setiap sprint; durasi disesuaikan agar efisien bagi tim beranggotakan 4 orang (Fahmy, Mike, Fadhi W, Avhan HB).

Ceremony	Kapan	Durasi	Peserta	Tujuan
Sprint Planning	Hari Senin pertama sprint, 09.00 WIB	2 jam	Fahmy, Mike, Fadhi W, Avhan HB	Menetapkan sprint goal, memilih backlog sesuai kapasitas, dan membedah kebutuhan keamanan
Daily Stand-up	Setiap hari kerja, 09.15 WIB	15 menit	Fahmy, Mike, Fadhi W, Avhan HB	Sinkronisasi harian: apa yang selesai kemarin, target hari ini, serta identifikasi blocker teknis/keamanan
Backlog Refinement	Hari Rabu minggu kedua, 14.00 WIB	1 jam	Avhan HB, Fahmy, Mike, Fadhi W	Merinci user story sprint berikutnya, memperbarui kriteria acceptance, dan estimasi story points
Sprint Review	Hari Jumat terakhir sprint, 14.00 WIB	1 jam	Seluruh tim pengembang, Avhan HB, Stakeholder KKUI	Mendemokan produk yang telah Done di staging dan menghimpun feedback langsung
Sprint Retrospective	Hari Jumat terakhir sprint, 15.30 WIB	45 menit	Fahmy, Mike, Fadhi W, Avhan HB	Evaluasi proses kerja internal tim (Start, Stop, Continue) dan menyepakati action items perbaikan proses/kualitas

Jadwal tetap tim: Daily Stand-up pukul 09.15 WIB, Sprint Planning hari Senin minggu ke-1, Review dan Retrospective hari Jumat minggu ke-2.

Template Sprint Review dan Retrospective

Salin dua tabel ini di akhir setiap sprint; review menilai produk, retrospective menilai cara kerja.

Sprint Review (Sprint 1)

Story	Status	Catatan stakeholder	Tindak lanjut
US-01 (Pendaftaran Mandiri & Berkas)	Diterima	Alur upload berkas KTP dan Kartu Pegawai berjalan lancar; validasi format file ketat	Tambahkan kompresi gambar otomatis di sisi klien sebelum upload
US-02 (Native Auth & 2FA TOTP)	Diterima	Pengamanan MFA TOTP berfungsi optimal; penguncian akun setelah 3 kali gagal mencegah brute force	Siap digunakan untuk role operasional di Sprint 2
US-03 (KYC Internal Reviewer & AML)	Diterima	Presigned URL 5 menit efektif melindungi dokumen KTP dari kebocoran data (ISO 27001)	Lanjut integrasi ke modul simpanan & pinjaman

Sprint goal tercapai: Ya. Story point selesai: 15 dari 15 yang direncanakan.

Sprint Retrospective (Sprint 1)

Mulai lakukan (Start)	Hentikan (Stop)	Teruskan (Continue)
Menjalankan scan keamanan SAST lokal sebelum membuat Pull Request	Menunggu akhir sprint untuk menguji integrasi audit trail	Peer review aktif antara Fahmy & Mike serta security review oleh Fadhi W

Aksi perbaikan	Penanggung jawab	Tenggat
Setup pre-commit hook otomatis untuk deteksi rahasia/kredensial bocor (TruffleHog / GitGuardian)	Fadhi W	21 November 2026
Buat komponen modal reusable untuk konfirmasi PIN 2FA pada modul pinjaman	Fahmy	23 November 2026

Metrik dan Pelacakan

Velocity dan burndown memantau kemajuan sprint; metrik keamanan dan kepatuhan melengkapi gambaran mutu software finansial.

Metrik	Arti	Cara menghitung
Velocity	Kapasitas penyelesaian pekerjaan tim per sprint	Total story points dari seluruh user story yang berstatus Done pada akhir sprint (~15-16 SP per sprint untuk Fahmy & Mike)
Burndown	Sisa pekerjaan harian terhadap target sprint	Sisa estimasi jam / story point di sprint backlog yang diperbarui setiap Daily Stand-up
OWASP Vulnerability Density	Kerapatan temuan kerentanan keamanan perangkat lunak	Jumlah kerentanan (Critical/High/Medium) per 1.000 baris kode (KLOC) pada hasil scan SAST/DAST
Audit Trail Integrity Rate	Keandalan pencatatan log transaksi (ISO 27001)	(Jumlah transaksi finansial dengan log audit lengkap / Total transaksi riil) x 100% (Wajib 100%)
System Uptime & Availability	Ketersediaan server VPS operasional	(Total jam operasional - downtime) / Total jam operasional x 100% (Target ≥ 99,5%)
Defect escape rate	Kualitas pengujian staging sebelum produksi	Jumlah bug/vulnerability yang ditemukan setelah rilis ke production

Lembar pelacakan per sprint

Sprint	Story point direncanakan	Story point selesai	Vulnerability lolos (Crit/High)	Bug lolos ke produksi	Sprint goal tercapai
Sprint 1	15	15	0	0	Ya
Sprint 2	16	[angka]	[angka]	[angka]	[ya / sebagian / tidak]
Sprint 3	15	[angka]	[angka]	[angka]	[ya / sebagian / tidak]
Sprint 4	16	[angka]	[angka]	[angka]	[ya / sebagian / tidak]
Sprint 5	15	[angka]	[angka]	[angka]	[ya / sebagian / tidak]
Sprint 6	13	[angka]	[angka]	[angka]	[ya / sebagian / tidak]

Pakai rata-rata velocity tiga sprint terakhir sebagai dasar memilih story di Sprint Planning berikutnya.

Log Risiko dan Impediment

Catat risiko yang mungkin terjadi dan hambatan yang sedang terjadi; tinjau log ini di setiap Daily Stand-up dan Retrospective.

ID	Jenis	Deskripsi	Dampak	Kemungkinan	Rencana penanganan	Penanggung jawab	Status
R-01	Risiko	Keterbatasan bandwidth pengembang karena tim beranggotakan 2 Fullstack Devs (Fahmy & Mike) saat terjadi bug regresi atau revisi fitur mendadak	Tinggi	Sedang	Terapkan batasan WIP (Work In Progress) ketat, manfaatkan scaffolding template UI/API React/Node.js, dan otomatisasi test coverage pada CI pipeline	Avhan HB & Fahmy	Terbuka
R-02	Risiko	Penumpukan antrean verifikasi berkas manual pendaftaran anggota jika volume pendaftar melonjak	Sedang	Sedang	Buat dashboard filtering SLA untuk Admin Frontdesk dengan alert eskalasi otomatis ke Manajer jika tiket pendaftaran > 12 jam belum diproses	Mike	Terbuka
R-03	Risiko	Kebocoran data dokumen KTP anggota saat proses transmisi atau penyimpanan storage di VPS	Sangat Tinggi	Rendah	Enkripsi data at-rest di storage file terenkripsi menggunakan AES-256 dan akses hanya via presigned URL sementara (5 menit) sesuai ISO 27001	Fadhi W & Mike	Teratasi

ID	Jenis	Deskripsi	Dampak	Kemungkinan	Rencana penanganan	Penanggung jawab	Status
R-04	Risiko	Utilisasi resource CPU/RAM pada Single Linux VPS melebihi ambang batas 70% saat beban puncak transaksi	Sedang	Sedang	Setup alert monitoring otomatis (Uptime, CPU/RAM threshold) dan siapkan playbook scale-up spesifikasi VPS atau pemisahan database ke managed instance jika utilisasi konsisten > 70%	Fadhi W	Terbuka
I-01	Impediment	Akses kredensial sandbox e-Sign belum diterbitkan oleh vendor rekanan	Tinggi	-	Avhan HB mengeskalasi ke bagian legal/pengadaan untuk mempercepat persetujuan NDA dan SLA sandbox	Avhan HB	Terbuka
I-02	Impediment	Keterlambatan input data master atau approval dari user/klien yang berpotensi menggeser jadwal sprint	Tinggi	-	Terapkan SLA governance matriks tanggung jawab SOW (SLA approval user 3 hari kerja; keterlambatan diproses via formal change request)	Avhan HB	Terbuka

BAGIAN 2: PRODUCT REQUIREMENT DOCUMENT (PRD)

Product Requirement Document (PRD)

KKUI Loan Services & Member Portal

Aplikasi Web Layanan Keuangan Anggota & Operasional Backoffice Koperasi Karyawan

Informasi Dokumen

- **Nama Proyek:** KKUI Loan Services & Member Portal
- **Product Owner & Scrum Master:** Avhan HB (KKUI)
- **Lead Fullstack Developer:** Fahmy (PT Parvata Jingga)
- **Core & Backoffice Fullstack Developer:** Mike (PT Parvata Jingga)
- **Cyber Security & DevSecOps Engineer:** Fadhi W (PT Parvata Jingga)
- **Status Dokumen:** Approved / Baseline Version 1.2
- **Tanggal Rilis:** 7 November 2026
- **Standar Kepatuhan:** OWASP ASVS v4.0 Level 2, ISO/IEC 27001:2022 ISMS, ISO/IEC 27701 (UU PDP)
- **Infrastruktur Target:** Single Linux VPS Ubuntu 24.04 LTS (4 vCPU / 8 GB RAM / 100–150 GB NVMe / 300 Anggota)

1. Pendahuluan & Latar Belakang

1.1 Latar Belakang

Koperasi Karyawan Usaha Bersama (KKUI) melayani sekitar 300 anggota aktif yang memerlukan akses pembiayaan cepat dan pengelolaan tabungan transparan. Proses pembiayaan dan administrasi simpanan manual sebelumnya menghadapi sejumlah kendala:

1. Waktu persetujuan pinjaman (*Turnaround Time*) memakan waktu berhari-hari akibat proses verifikasi manual dan tanda tangan fisik.
2. Risiko kredit macet (*Non-Performing Loan / NPL*) yang sulit dimitigasi tanpa otomasi pengecekan rasio pemotongan gaji (*Debt Service Ratio*) dan histori riwayat kredit.
3. Beban rekonsiliasi manual antara tagihan simpan pinjam dan pemotongan gaji (payroll) oleh tim HRD setiap akhir bulan yang rawan selisih.
4. Kebutuhan kedaulatan data dan kepatuhan hukum finansial, di mana data transaksi dan berkas identitas anggota tidak boleh bergantung pada vendor pihak ketiga yang rentan kebocoran data.
5. **Kemandirian Sistem SLIK / Credit Scoring:** Koperasi tidak menggunakan koneksi live API langsung ke OJK (Sistem Layanan Informasi Keuangan), melainkan **membangun mesin integrasi scoring kredit mandiri (*Internal Credit Scoring & Historical SLIK Engine*)** yang mengagregasi data historis pinjaman internal, data potongan HRD, dan parser file dokumen SLIK / iDeb terverifikasi yang diunggah anggota/admin.

1.2 Tujuan Produk

- **Akselerasi Layanan:** Menurunkan SLA persetujuan dan pencairan pinjaman risiko rendah/payroll menjadi < 24 jam.
- **Otomasi Tata Kelola Risiko Mandiri:** Menerapkan sistem seleksi pinjaman 3 jalur (*Payroll PR23, Saldo Sukarela, Payment Gateway*) berbasis rasio cicilan terhadap gaji dan mesin integrasi scoring kredit mandiri (*Internal Credit Scoring Engine*).
- **Keamanan Finansial Berstandar Industri:** Menerapkan autentikasi mandiri (*Argon2id + MFA TOTP*), enkripsi data *at-rest* (AES-256) & *in-transit* (TLS 1.3), serta *Immutable Audit Trail* (ISO 27001).
- **Efisiensi Treasury:** Mengotomatiskan rekonsiliasi payroll HRD (PR23) dan pencairan instan via API Disbursement Bank dengan mekanisme *Dual Authorization*.

2. Personel, Aktor Sistem, & Hak Akses (RBAC)

Berdasarkan kontrol pemisahan wewenang (*Segregation of Duties* - ISO 27001 Control A.6.1.2), sistem mendefinisikan 6 aktor utama:

Aktor / Peran	Lingkungan Akses	Deskripsi & Batas Wewenang
Anggota Reguler / Calon Anggota	Portal Anggota (*Mobile & Desktop Responsive*)	Mendaftar mandiri, verifikasi berkas, melihat saldo & mutasi simpanan, simulasi pinjaman, mengajukan kredit (Barang & Jasa, Dana Tunai, UMKM), mengunggah berkas histori kredit/iDeb mandiri (jika diminta), penandatanganan akad digital e-Sign, dan pembayaran cicilan via VA.

Aktor / Peran	Lingkungan Akses	Deskripsi & Batas Wewenang
Admin Frontdesk	Portal Backoffice	Verifikasi kelayakan dokumen pendaftaran anggota (KTP, Slip Gaji, ID Card), screening awal AML/PEP, reviewer tahap 1 pengajuan kredit (input/verifikasi parameter scoring kredit internal), dan operasional CS/katalog.
Manajer Operasional	Portal Backoffice	Approval tingkat 2 pendaftaran anggota, persetujuan kredit (LOS) untuk plafon menengah berbasis hasil rekomendasi scoring internal, penyesuaian (*adjustment*) plafon/tenor, dan monitoring SLA tiket.
Bendahara Treasury	Portal Backoffice	Approval tingkat akhir pencairan dana (LOS), verifikasi saldo buffer rekening penampung, eksekusi automated Bank Disbursement API, upload & rekonsiliasi file payroll HRD (PR23).
Ketua Koperasi (Eksekutif)	Portal Backoffice	Otorisasi pencairan kredit bernilai besar (*Over-limit authorization / Dual Control*), evaluasi restrukturisasi kredit macet, dan pemantauan Dashboard Laba Rugi/NPL/RAT.
Super Admin IT & Security	Portal Backoffice / Server	Pengelolaan parameter sistem (bunga, denda, tenor, bobot formula credit scoring), manajemen akun pegawai, monitoring log keamanan/audit trail WORM, dan pemeliharaan server VPS Linux.

3. Spesifikasi Fungsional: Portal Anggota (31 Submodul)

3.1 Modul Autentikasi Mandiri & Pendaftaran (Tanpa SSO & e-KYC Eksternal)

- **FR-AUTH-01 (Pendaftaran Mandiri):** Calon anggota mendaftar menggunakan Email resmi/pribadi, Nomor HP/WhatsApp, NIK, dan kata sandi kuat (minimal 12 karakter, huruf besar, kecil, angka, simbol).
- **FR-AUTH-02 (Verifikasi OTP Email):** Sistem mengirimkan kode token OTP 6 digit via email dengan masa kedaluwarsa 5 menit dan proteksi rate limiter maksimal 3 kali pengiriman per jam.
- **FR-AUTH-03 (Unggah Berkas Keanggotaan):** Calon anggota wajib mengunggah foto KTP, Kartu Pegawai/ID Card, dan Slip Gaji terbaru. Sistem memvalidasi MIME type (JPEG/PNG/PDF, maks 3 MB per file) serta menyimpan berkas ke storage terisolasi dengan enkripsi AES-256. Akun berstatus `Pending Verification` hingga disetujui Admin Frontdesk dan Manajer.
- **FR-AUTH-04 (Native Login & Anti-Brute Force):** Login menggunakan email dan password. Sandi diverifikasi menggunakan *Argon2id*. Jika terjadi kegagalan login berturut-turut sebanyak 3 kali, akun terkunci selama 15 menit dan menampilkan tantangan CAPTCHA.
- **FR-AUTH-05 (MFA TOTP RFC 6238):** Anggota dan staf dapat mengaktifkan verifikasi dua langkah berbasis aplikasi autentikator (Google Authenticator / Aegis) lengkap dengan QR enrollment dan 8 kode cadangan darurat (*emergency backup codes*).

3.2 Modul Simpanan & Investasi (Pemisahan Modul Mandiri)

- **FR-SIMP-01 (Modul Simpanan Pokok):**
- Tampilan saldo pokok keanggotaan dan uang buku.
- Fitur unduh tanda terima/bukti bayar uang buku digital.
- Fitur unduh e-Sertifikat Keanggotaan PDF resmi ber-watermark dinamis dan kode verifikasi QR.
- Riwayat transaksi simpanan pokok dengan filter rentang tanggal dan ekspor PDF/Excel.
- **FR-SIMP-02 (Modul Iuran Wajib):**
- Dasbor status iuran bulanan wajib (Status: Lunas / Menunggak).
- Mekanisme pembayaran kewajiban iuran wajib bulanan melalui pemotongan otomatis Payroll PR23 HRD atau pembayaran manual via Virtual Account Payment Gateway.
- Pelacakan akumulasi saldo iuran wajib selama masa aktif keanggotaan.
- Fitur unduh Rekening Koran khusus Iuran Wajib bulanan.
- **FR-SIMP-03 (Modul Simpanan Investasi):**
- Dasbor portofolio simpanan investasi khusus modal penyertaan usaha koperasi.
- Informasi proyeksi imbal hasil (*yield* / bagi hasil) dividen SHU (Sisa Hasil Usaha) tahunan secara transparan.
- Fitur penambahan dana (*Top-up* Saldo Investasi) mandiri menggunakan Virtual Account dinamis.
- Riwayat historis mutasi bagi hasil dan bukti setor penyertaan modal investasi.
- **FR-SIMP-04 (Modul Simpanan Sukarela):**
- Pengecekan saldo dan riwayat mutasi real-time simpanan sukarela harian.
- Fitur Setoran Sukarela: Pilihan via Payroll PR23 (terintegrasi HR) atau Non-Payroll (VA Dinamis Midtrans/Xendit).

- Pengecekan rasio tunggakan internal: jika ada tunggakan cicilan kredit macet, saldo sukarela dapat didebet untuk menutup cicilan.
- Fitur Penarikan Sukarela: Diamankan konfirmasi PIN transaksi 6 digit; approval multi-tier (Admin, Manajer, Bendahara); pencairan otomatis via Bank Disbursement API ke rekening bank anggota.
- **FR-SIMP-05 (Modul SISKA - Simpanan Sukarela Berjangka / Deposito):**
- Pendaftaran bilyet deposito digital (pilihan tenor 3, 6, 12 bulan) dengan tingkat bagi hasil kompetitif.
- Penerbitan e-Bilyet Sertifikat digital resmi ber-barcode integritas data.
- Opsi Jatuh Tempo Fleksibel: Perpanjangan Pokok + Bunga Otomatis (ARO), Perpanjangan Pokok saja (Bunga cair otomatis ke Simpanan Sukarela), atau Pencairan Pokok + Bunga ke rekening bank.
- Pencairan Sebelum Jatuh Tempo (*Early Break*): Otomasi kalkulator penalti (memotong penalti administrasi closing sebesar 1,5% dari pokok) dan wajib persetujuan Manajer & Bendahara sebelum eksekusi API transfer.
- **FR-SIMP-06 (Modul Simpanan SMS & Simpanan Pendidikan):**
- Tabungan tematik rencana masa depan (Simpanan Masa Sekolah / Pendidikan dan Simpanan Mitra Sejahtera / SMS).
- Formulir pendaftaran program tabungan berjangka dengan skema autodebet payroll PR23 terjadwal.
- Penarikan terjadwal saat jatuh tempo (auto-mutasi ke Simpanan Sukarela) atau pengajuan penarikan awal dengan kalkulasi penalti penutupan buku.

3.3 Modul Pinjaman & Kredit

A. Kredit Barang & Jasa (e-Katalog)

- **FR-LOAN-01 (e-Katalog & Simulasi):** Katalog produk barang/elektronik/sembako koperasi; kalkulator simulasi tenor (3, 6, 12, 24 bulan) dengan rincian pokok, margin/bunga, dan angsuran bulanan.
- **FR-LOAN-02 (Pengecekan Rasio Utang & Mesin Scoring Kredit Mandiri):**
- Sistem mengalkulasi kelayakan kredit menggunakan **Internal Credit Scoring Engine** yang menggabungkan:
  1. Rasio Beban Utang (*Debt Service Ratio / DSR*): Total cicilan berjalan dibagi gaji bersih bulanan.
  2. Rekam Jejak Kolektibilitas Internal: Riwayat ketepatan pembayaran cicilan dan simpanan wajib di koperasi KKUI selama 12 bulan terakhir.
  3. Parser Data Riwayat Kredit (SLIK/iDeb PDF Parser): Modul upload berkas iDeb mandiri/input manual catatan kredit luar oleh Admin Frontdesk.
- *Jalur Aman (DSR < 33% & Skor Kredit Tinggi):* Lolos langsung ke formulir pengajuan standar dengan skema pemotongan payroll PR23 tanpa uang muka (DP 0%).
- *Jalur Berisiko (DSR >= 33% atau Skor Kredit Sedang):* Sistem mewajibkan pembayaran Uang Muka (DP) via potong saldo sukarela atau transfer tunai VA sebelum pengajuan diproses ke komite.
- **FR-LOAN-03 (e-Sign Akad Kredit):** Begitu disetujui, debitur menandatangani perjanjian pembiayaan digital tersertifikasi.

B. Pinjaman Dana Tunai

- **FR-LOAN-04 (Pengajuan Pinjaman Baru & Top Up):** Verifikasi PIN transaksi 6 digit; pengajuan plafon pinjaman tunai; validasi batas maksimal pinjaman (maksimal 3x total simpanan atau 40% sisa gaji bersih); simulasi tabel amortisasi berbasis skor kredit internal.
- **FR-LOAN-05 (Restrukturisasi Pinjaman):** Anggota yang mengalami kendala finansial dapat mengajukan:
- *Pengurangan Nilai Angsuran (Perpanjangan Tenor):* Menghitung ulang jadwal cicilan baru dan memotong bunga berjalan.
- *Pelunasan Sebagian:* Pembayaran sebagian pokok via Virtual Account untuk menurunkan angsuran bulanan.

C. Pinjaman Modal Usaha UMKM (Logika 3 Jalur Risiko)

- **FR-LOAN-06 (Skrining 3 Jalur Kelayakan):** Sistem mengevaluasi rasio beban utang (*Debt Service Ratio / DSR*) terhadap estimasi penghasilan anggota:
- **Jalur Hijau (DSR < 33%):** Pembayaran cicilan otomatis dipotong dari gaji melalui sistem Payroll PR23 HRD. Persetujuan cepat (Admin + Manajer + Bendahara) dengan SLA < 24 jam.
- **Jalur Kuning (DSR 33% – 50%):** Pembayaran cicilan menggunakan skema auto-debet dari rekening Simpanan Sukarela anggota. Membutuhkan verifikasi saldo cadangan minimal 2x angsuran.
- **Jalur Merah (DSR > 50%):** Pembayaran cicilan wajib melalui penerbitan Virtual Account (Payment Gateway) secara mandiri setiap bulan dan membutuhkan jaminan tambahan atau persetujuan khusus Ketua Koperasi.

4. Spesifikasi Fungsional: Portal Backoffice (10 Submodul)

- **FR-BO-01 (Dashboard Operasional):** Metrik real-time: total pencairan dana hari ini, jumlah permohonan kredit pending, status SLA tiket, total simpanan masuk, dan saldo buffer rekening disbursement bank.
- **FR-BO-02 (Manajemen Anggota / Member 360 & KYC Queue):**
- Antrean verifikasi dokumen pendaftaran baru dengan *temporary secure document viewer* (presigned URL 5 menit).
- Pengecekan otomatis daftar nama terhadap *Internal AML/PEP Watchlist*.
- Pembuatan otomatis nomor CIF dan nomor rekening simpanan setelah disetujui 3 lapis (Admin, Manajer, Bendahara).
- **FR-BO-03 (Master Produk Simpanan & Pinjaman):** Manajemen parameter suku bunga, margin, tenor minimal/maksimal, persentase penalti SISKA, plafon kredit, dan matriks bobot skoring kredit internal (*Credit Scoring Rule Engine*).
- **FR-BO-04 (LOS Approval Center & Internal Scoring Engine):**
- Antrean tugas berbasis SLA: status Hijau (Aman), Kuning (Menjelang Batas 24 Jam), Merah (Overdue / Auto-Eskalasi ke atasan).
- **Tampilan Panel Scoring Kredit Mandiri:** Menampilkan skor kredit komposit (A / B / C / D), rincian DSR, riwayat kolektibilitas internal KKUI, dan catatan verifikasi kredit eksternal yang diinput staf.
- Panel Keputusan: *Approve*, *Reject* (dengan catatan alasan baku), *Revise* (kembalikan ke anggota), atau *Adjustment* (penyesuaian plafon/tenor/DP).
- Monitoring status penandatanganan akad e-Sign secara real-time.
- **FR-BO-05 (Treasury & Cash Disbursement API):**
- Antrean pencairan dana otomatis untuk tiket yang telah menandatangani e-Sign.
- Pengecekan saldo buffer bank sebelum eksekusi API.
- *Dual Control Authorization:* Pencairan di atas limit nominal tertentu (mis. > Rp25.000.000) wajib mendapatkan otorisasi ganda/token persetujuan dari Ketua Koperasi.
- Sinkronisasi otomatis ke Buku Besar (*General Ledger / GL*) dan akun CIF anggota saat transfer bank sukses.
- **FR-BO-06 (Manajemen Payroll PR23 & Rekonsiliasi):**
- Fitur generate dan unduh file cut-off tagihan bulanan format CSV/Excel untuk diserahkan ke tim HRD.
- Fitur unggah file hasil potongan gaji riil dari HRD dengan validasi integritas checksum SHA-256.
- Mesin auto-rekonsiliasi: mencocokkan tagihan vs potongan riil. Transaksi sukses otomatis meng-update jurnal GL; potongan gagal/kurang otomatis dicatat sebagai tunggakan (*arrears*) dan memperbarui status kolektibilitas.
- **FR-BO-07 (Core Deposit & Loan Servicing Batch Engine):**
- EOD Batch Simpanan: Eksekusi otomatis perpanjangan ARO SISKA pada tanggal jatuh tempo.
- EOD Batch Pinjaman: Pengecekan keterlambatan pembayaran, kalkulasi denda otomatis, pembaruan status kolektibilitas (Kolektibilitas 1 s/d 5), dan pemicu pengiriman Surat Peringatan (SP) via WhatsApp Gateway.
- **FR-BO-08 (CMS Konten & Katalog):** Pengelolaan produk katalog barang/jasa, banner promosi, artikel edukasi koperasi, dan broadcast pesan notifikasi massal ke anggota.
- **FR-BO-09 (User, Role & Permission Engine):** Pengelolaan akun staf backoffice dan penegakan matriks hak akses (*Least Privilege*).
- **FR-BO-10 (Immutable Audit Trail & System Log):** Viewer pencatatan log permanen (WORM) untuk seluruh aktivitas kritis pegawai: IP address, timestamp, ID staf, aksi yang dilakukan, dan status keberhasilan.

5. Arsitektur Mesin Scoring Kredit Mandiri (*Internal Credit Scoring Engine*)

Sebagai pengganti ketergantungan koneksi live API OJK, sistem menggunakan mesin penilaian kredit mandiri yang dibangun di dalam aplikasi:

```
 [Data Input Anggota]
   • Gaji Pokok & Tunjangan (Slip Gaji Terverifikasi)
   • Plafon & Angsuran Baru yang Diajukan
   • Berkas Riwayat Kredit / iDeb (Opsional/Manual)
          |
          ▼
[Mesin Analisis Scoring Mandiri (Node.js Core Engine)]
   ├─ Bobot 40%: Debt Service Ratio (DSR) -> Rumus: (Total Angsuran / Gaji Bersih) x 100%
   ├─ Bobot 30%: Histori Pembayaran Internal KKUI (12 Bulan Terakhir)
   ├─ Bobot 20%: Masa Kerja & Status Kepegawaian (HRD Data Sync)
   └─ Bobot 10%: Rasio Total Simpanan Terhadap Pinjaman Diajukan
          |
```

```
          ▼
[Hasil Skor Komposit Internal]
  • Skor A (80 - 100): Risiko Sangat Rendah -> Auto-Pass Jalur Hijau (Tanpa DP)
  • Skor B (65 - 79): Risiko Rendah / Sedang -> Lolos Jalur Hijau / Kuning
  • Skor C (50 - 64): Risiko Tinggi -> Wajib DP via Sukarela atau Transfer VA
  • Skor D (< 50): Risiko Kritis -> Rekomendasi Reject / Wajib Otorisasi Khusus Ketua
```

6. Matriks Otorisasi Persetujuan Kredit & Keuangan

Untuk menegakkan prinsip *Segregation of Duties* dan memitigasi risiko fraud, batas wewenang persetujuan diatur sebagai berikut:

Nominal Pengajuan Kredit	Pemeriksa 1 (Admin Frontdesk)	Penyetuju 1 (Manajer Operasional)	Penyetuju 2 (Bendahara Treasury)	Otorisasi Akhir (Ketua Koperasi)
≤ Rp5.000.000 (Mikro / Sembako)	Verifikasi Berkas & Skor Internal	Review & Approval	Approval Pencairan	-
Rp5.000.001 – Rp25.000.000 (Reguler)	Verifikasi Berkas & Skor Internal	Review & Approval	Approval Pencairan & Buffer Check	Notifikasi Tembusan
> Rp25.000.000 (Plafon Besar / UMKM)	Verifikasi Berkas & Skor Internal	Review Kelayakan	Verifikasi Kas Treasury	**Wajib Approval Token / Dual Control**
Restrukturisasi Pinjaman Macet	Analisis Rasio Baru	Rekomendasi Tenor	Verifikasi Amortisasi	**Wajib Approval Ketua**

7. Persyaratan Non-Fungsional (NFR)

7.1 Kinerja & Kapasitas (Sizing Single VPS 300 Anggota)

- **Concurrent Users:** Mampu menangani 30–60 pengguna aktif bersamaan tanpa penurunan performa pada server VPS 4 vCPU / 8 GB RAM.
- **Waktu Respon API:** Rata-rata waktu respon API internal ≤ 300 ms untuk transaksi standar dan ≤ 1,5 detik untuk eksekusi pelaporan/batch agregasi.
- **Ketersediaan Sistem (Availability):** Target uptime server ≥ 99,5% dalam jam operasional normal.
- **Threshold Alert:** Alert otomatis terkirim ke SecOps/DevOps jika utilisasi CPU atau RAM VPS melebihi 70% selama lebih dari 10 menit berturut-turut.

7.2 Keamanan & Kepatuhan Regulasi (OWASP ASVS & ISO 27001)

- **Kerahasiaan Data (Confidentiality):** Data sensitif (NIK, slip gaji, nomor rekening) dienkripsi pada database menggunakan algoritma AES-256-GCM. Berkas dokumen KTP disimpan dalam direktori privat dengan akses presigned URL berumur maksimal 5 menit.
- **Integritas Transaksi (Integrity):** Seluruh mutasi kas dan buku besar dilindungi transaksi ACID PostgreSQL; pencegahan *double-spending* atau *race condition* penarikan saldo menggunakan distributed lock Redis.
- **Audit Trail (Non-Repudiation):** Log audit bersifat *write-once* (append-only), mencatat identitas pelaku, IP, user-agent, timestamp, dan perubahan state data finansial.
- **Security Headers & Network Hardening:** Nginx dikonfigurasi dengan TLS 1.3, HSTS (HTTP Strict Transport Security), Content Security Policy (CSP), X-Frame-Options: DENY, dan firewall UFW hanya membuka port 80/443 serta port SSH khusus berbasis otentikasi SSH Key (tanpa password root).

7.3 Backup & Rencana Pemulihan Bencana (Disaster Recovery)

- **Backup Rutin:** Dump database otomatis dijalankan setiap malam pukul 02.00 WIB dan dikirim ke penyimpanan *offsite* terpisah dengan retensi data 14–30 hari.
- **Recovery Time Objective (RTO):** Waktu maksimal pemulihan sistem dari snapshot cadangan adalah ≤ 4 jam jika terjadi kegagalan server fisik.
- **Recovery Point Objective (RPO):** Kehilangan data maksimal jika terjadi insiden fatal adalah ≤ 24 jam (sesuai siklus backup harian).

8. Rencana Integrasi Sistem Pihak Ketiga (Tanpa API Eksternal OJK)

Sistem Eksternal / Subsistem	Protokol Integrasi	Tujuan Fungsional	Mitigasi Kegagalan (Fallback)
Mesin Scoring Kredit Internal (SLIK Mandiri)	Modul Internal (Node.js Service)	Pengecekan scoring kredit komposit (DSR, histori KKUI, data HRD, iDeb parser)	Menggunakan data histori internal secara default jika dokumen eksternal tidak diunggah
Penyedia e-Sign Tersertifikasi	REST API & Webhook	Penandatanganan digital sah atas perjanjian kredit dan fidusia	Notifikasi pengingat otomatis ke WhatsApp anggota; opsi unduh dokumen fisik jika vendor gangguan
Payment Gateway (Midtrans/Xendit)	REST API & Webhook (VA Dinamis)	Penerbitan nomor Virtual Account untuk pembayaran cicilan dan setoran simpanan non-payroll	Verifikasi webhook dengan signature SHA-512; rekonsiliasi berkala harian status VA settlement
Automated Bank Disbursement API	REST API Mutasi & Transfer Bank	Eksekusi transfer pencairan pinjaman tunai langsung ke rekening bank anggota	Pengecekan saldo buffer sebelum transfer; antrean retry manual jika jaringan bank maintenance
Sistem HRD Perusahaan (PR23)	File Parser CSV/Excel & SFTP Sync	Pertukaran data bulanan tagihan pinjaman vs realisasi pemotongan gaji karyawan	Validasi format file baku dan hashing SHA-256 sebelum pemrosesan data ke buku besar
WhatsApp Gateway	REST API Message Broker	Pengiriman OTP registrasi, reminder jatuh tempo, dan notifikasi Surat Peringatan (SP) cicilan	Fallback pengiriman notifikasi melalui email anggota jika nomor WhatsApp tidak terjangkau

9. Alokasi Milestone & Rencana Peluncuran (Release Roadmap)

Mengikuti timeline kesepakatan 15–21 minggu (6 Sprint aktif @ 2 minggu):

```
 Fase 1: Discovery, BRD & Desain Arsitektur (Minggu 1-2) ──> SELESAI
Fase 2: Finalisasi UI/UX & Scaffolding Database (Minggu 3-4)
Fase 3: Sprint 1 - Core Native Auth, Berkas KTP, RBAC Backoffice (Minggu 5-6)
Fase 4: Sprint 2 - Dashboard Simpanan, Iuran Wajib, Investasi & Kredit BJ (Minggu 7-8)
Fase 5: Sprint 3 - LOS Approval Center, Mesin Scoring Mandiri, e-Sign & Disbursement API [RILIS 1 - MVP] (Minggu 9-10)
Fase 6: Sprint 4 - Pinjaman Dana Tunai & UMKM 3 Jalur (Minggu 11-12)
Fase 7: Sprint 5 - Otomasi Payroll PR23 & Simpanan SISKA ARO (Minggu 13-14)
Fase 8: Sprint 6 - Executive BI Reporting, EOD Denda & RAT Export [RILIS 2 - FULL SCOPE] (Minggu 15-16)
Fase 9: Hardening Keamanan, Vulnerability Assessment / Pentest & UAT Formal (Minggu 17-18)
Fase 10: Deployment Production VPS Linux & Handover Source Code (Minggu 19)
Fase 11: Masa Garansi Bug & Maintenance 90 Hari (Minggu 20 s/d Selesai)
```

10. Kriteria Penerimaan Proyek (Acceptance Criteria & Sign-Off)

Proyek dinyatakan selesai dan dapat diserahterimakan apabila memenuhi kondisi:

1. **Fungsional Selesai:** Seluruh 41 kelompok fungsi (31 submodul anggota dan 10 submodul backoffice) berfungsi sesuai alur proses pada diagram dan lolos pengujian skenario bisnis.
2. **Kepatuhan Keamanan Lolos:** Lolos pengujian kerentanan (*Penetration Testing*) tanpa adanya temuan celah keamanan berstatus *Critical* atau *High*, serta konfigurasi Nginx/WAF memenuhi standar OWASP ASVS Level 2.
3. **Pencatatan Audit Trail Aktif:** Seluruh mutasi keuangan dan aksi administratif terbukti tercatat di *Immutable Audit Log* ISO 27001.
4. **UAT Formal Disetujui:** Berita Acara UAT ditandatangani secara resmi oleh **Avhan HB** mewakili pihak KKUI.
5. **Serah Terima Aset Lengkap:** Penyerahan source code aplikasi, skrip migrasi database, dokumentasi API Swagger, panduan instalasi server VPS, dan panduan penggunaan admin (*Admin Manual Guide*).

Spesifikasi Arsitektur Teknis, ERD Database & Kontrak API

KKUI Loan Services & Member Portal

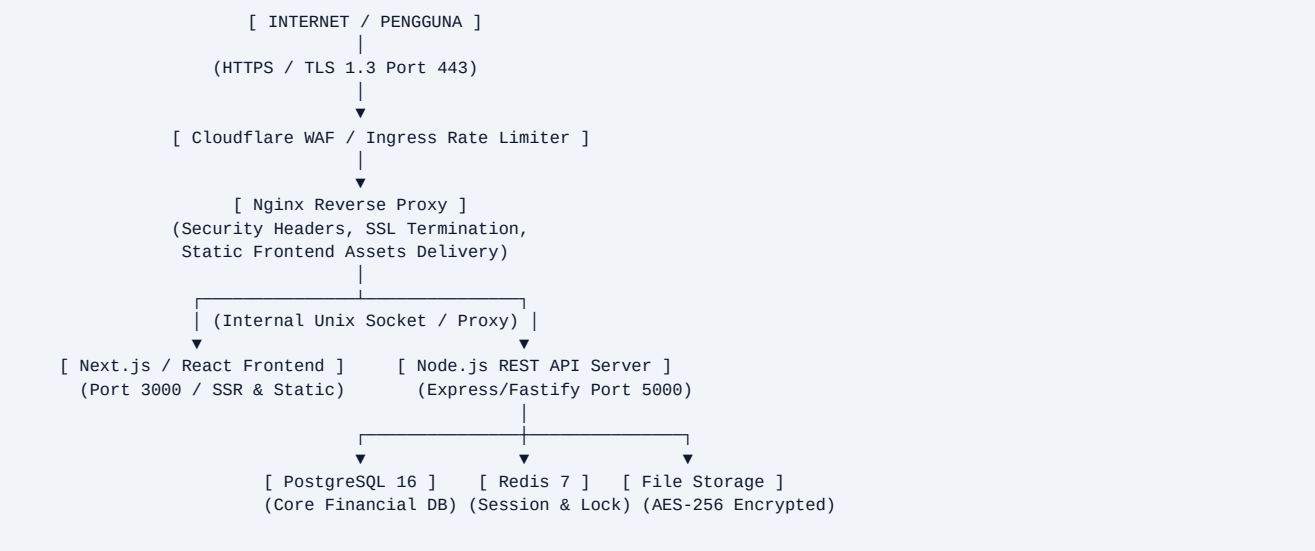
Panduan Teknis Arsitektur Perangkat Lunak, Model Data PostgreSQL & Kontrak RESTful API

Informasi Dokumen

- **Proyek:** KKUI Loan Services & Member Portal
- **Product Owner & Scrum Master:** Avhan HB (KKUI)
- **Lead Fullstack Developer:** Fahmy (PT Parvata Jingga)
- **Core & Backoffice Developer:** Mike (PT Parvata Jingga)
- **Cyber Security & DevSecOps:** Fadhi W (PT Parvata Jingga)
- **Versi Dokumen:** 1.0 (Baseline Sprint 1-6)
- **Tanggal:** 7 November 2026
- **Database Target:** PostgreSQL 16 LTS + Redis 7 (Caching, Queue & Distributed Locking)
- **Runtime Target:** Node.js 20 LTS / React 19 / Nginx Reverse Proxy pada Ubuntu 24.04 LTS

1. Arsitektur Sistem & Topologi Jaringan

Sistem mengadopsi pola arsitektur **Modular Monolith / Clean Architecture** yang di-deploy pada **Single Linux VPS (Ubuntu 24.04 LTS)** untuk melayani 300 anggota (30–60 concurrent users).



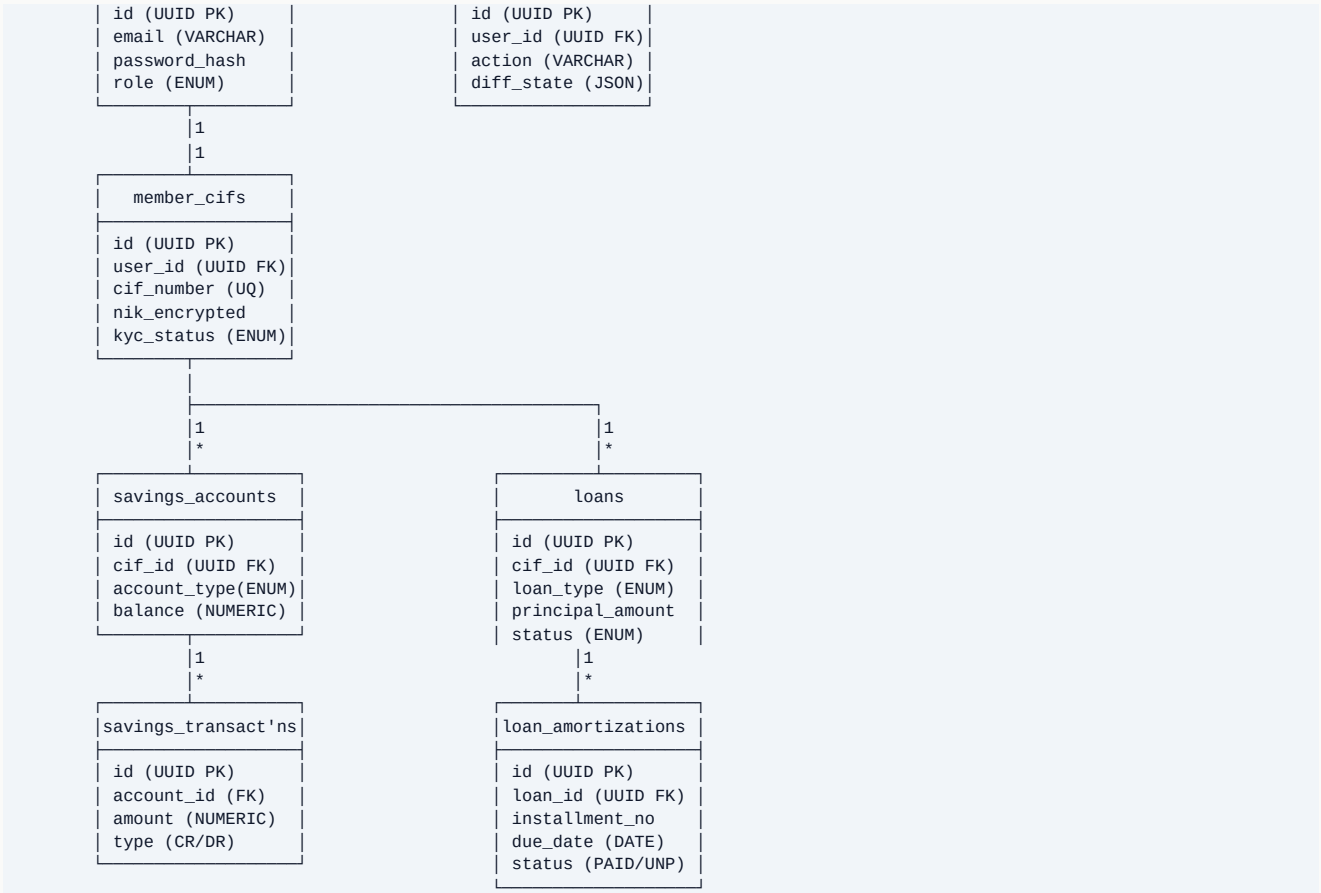
Standar Keamanan & Enkripsi Data

1. **In-Transit:** Wajib TLS 1.3 dengan Cipher Suite aman; HSTS aktif (`max-age=31536000; includeSubDomains; preload`).
2. **At-Rest Database:** Kolom sensitif (NIK, nomor rekening bank pribadi, nilai gaji) dienkripsi menggunakan **AES-256-GCM** dengan *Key Management Service (KMS)* lokal server.
3. **Storage Berkas KTP & Slip Gaji:** Berkas disimpan di direktori privat di luar web root (`/var/storage/kkui/vault/`) dengan nama file di-hash UUIDv4 dan hanya dapat diakses melalui mekanisme *Temporary Presigned URL* bertenggat waktu 5 menit.

2. Entity Relationship Diagram (ERD) & Skema Database

Seluruh tabel menggunakan UUIDv4 sebagai Primary Key untuk mencegah celah keamanan **IDOR (Insecure Direct Object Reference)** sesuai rekomendasi OWASP ASVS V4.





2.1 Definisi Tabel Utama (Data Dictionary)

A. Tabel `users` (Otentikasi & Akun)

```
CREATE TYPE user_role_enum AS ENUM (
    'MEMBER',
    'ADMIN_FRONTDESK',
    'MANAGER',
    'TREASURER',
    'CHAIRMAN',
    'SUPERADMIN'
);

CREATE TABLE users (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    email VARCHAR(255) UNIQUE NOT NULL,
    password_hash VARCHAR(255) NOT NULL, -- Argon2id hash
    phone_number VARCHAR(20) UNIQUE NOT NULL,
    role user_role_enum NOT NULL DEFAULT 'MEMBER',
    is_active BOOLEAN NOT NULL DEFAULT FALSE,
    is_mfa_enabled BOOLEAN NOT NULL DEFAULT FALSE,
    mfa_secret_encrypted VARCHAR(255),
    failed_login_count INT NOT NULL DEFAULT 0,
    locked_until TIMESTAMP WITH TIME ZONE,
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
    updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
CREATE INDEX idx_users_email ON users(email);
```

B. Tabel `member_cifs` (Data Anggota & Verifikasi Dokumen)

```
CREATE TYPE kyc_status_enum AS ENUM (
    'DRAFT',
    'PENDING_VERIFICATION',
    'APPROVED',
    'REJECTED'
);

CREATE TABLE member_cifs (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
```

```
    user_id UUID UNIQUE NOT NULL REFERENCES users(id) ON DELETE RESTRICT,
    cif_number VARCHAR(30) UNIQUE, -- Format: CIF-YYYYMM-XXXX
    full_name VARCHAR(255) NOT NULL,
    nik_encrypted BYTEA NOT NULL, -- AES-256 Encrypted NIK
    employee_id VARCHAR(50) NOT NULL,
    department VARCHAR(100) NOT NULL,
    ktp_file_path VARCHAR(255) NOT NULL,
    id_card_file_path VARCHAR(255) NOT NULL,
    slip_gaji_file_path VARCHAR(255) NOT NULL,
    kyc_status kyc_status_enum NOT NULL DEFAULT 'PENDING_VERIFICATION',
    verified_by_admin UUID REFERENCES users(id),
    verified_by_manager UUID REFERENCES users(id),
    rejection_reason TEXT,
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
    updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
CREATE INDEX idx_cifs_user ON member_cifs(user_id);
CREATE INDEX idx_cifs_status ON member_cifs(kyc_status);
```

C. Tabel `savings_accounts` (Rekening Simpanan)

```
CREATE TYPE savings_type_enum AS ENUM (
    'SIMPANAN_POKOK',
    'IURAN_WAJIB',
    'SIMPANAN_INVESTASI',
    'SIMPANAN_SUKARELA',
    'SISKA_BERJANGKA',
    'SIMPANAN_PENDIDIKAN',
    'SIMPANAN_SMS'
);

CREATE TABLE savings_accounts (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    cif_id UUID NOT NULL REFERENCES member_cifs(id) ON DELETE RESTRICT,
    account_number VARCHAR(30) UNIQUE NOT NULL, -- Format: SAV-[TYPE]-XXXXXX
    account_type savings_type_enum NOT NULL,
    balance NUMERIC(15, 2) NOT NULL DEFAULT 0.00 CHECK (balance >= 0),
    is_active BOOLEAN NOT NULL DEFAULT TRUE,
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
    updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
CREATE INDEX idx_savings_cif ON savings_accounts(cif_id);
```

D. Tabel `savings_transactions` (Mutasi Kas Simpanan)

```
CREATE TYPE transaction_type_enum AS ENUM ('CREDIT', 'DEBIT');

CREATE TABLE savings_transactions (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    account_id UUID NOT NULL REFERENCES savings_accounts(id) ON DELETE RESTRICT,
    transaction_code VARCHAR(50) UNIQUE NOT NULL, -- TX-SAV-YYYYMMDD-XXXXXX
    amount NUMERIC(15, 2) NOT NULL CHECK (amount > 0),
    type transaction_type_enum NOT NULL,
    balance_after NUMERIC(15, 2) NOT NULL,
    reference_id VARCHAR(100), -- Referensi VA / PR23
    description TEXT,
    created_by UUID REFERENCES users(id),
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
CREATE INDEX idx_savings_tx_acc ON savings_transactions(account_id);
```

E. Tabel `deposit_siska_bilyet` (Bilyet Deposito Berjangka)

```
CREATE TYPE aro_option_enum AS ENUM (
    'ARO_POKOK_BUNGA', -- Rollover Pokok + Bunga
    'ARO_POKOK_ONLY',  -- Rollover Pokok, Bunga Cair ke Sukarela
    'NON_ARO'          -- Cair Otomatis saat Jatuh Tempo
);

CREATE TABLE deposit_siska_bilyet (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    account_id UUID NOT NULL REFERENCES savings_accounts(id) ON DELETE RESTRICT,
    bilyet_number VARCHAR(50) UNIQUE NOT NULL, -- BLY-SISKA-YYYY-XXXXX
    principal_amount NUMERIC(15, 2) NOT NULL CHECK (principal_amount >= 1000000),
    annual_interest_rate NUMERIC(5, 2) NOT NULL, -- Contoh: 6.50%
    tenor_months INT NOT NULL CHECK (tenor_months IN (3, 6, 12)),
    aro_type aro_option_enum NOT NULL DEFAULT 'ARO_POKOK_BUNGA',
    start_date DATE NOT NULL,
    maturity_date DATE NOT NULL,
```

```
    is_active BOOLEAN NOT NULL DEFAULT TRUE,
    is_broken_early BOOLEAN NOT NULL DEFAULT FALSE,
    penalty_fee NUMERIC(15, 2) DEFAULT 0.00,
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
```

F. Tabel `loans` (Fasilitas Pinjaman)

```
CREATE TYPE loan_type_enum AS ENUM (
    'KREDIT_BARANG_JASA',
    'PINJAMAN_DANA_TUNAI',
    'PINJAMAN_UMKM'
);

CREATE TYPE loan_route_enum AS ENUM (
    'GREEN_PAYROLL_PR23',
    'YELLOW_AUTO_DEBET_SUKARELA',
    'RED_PAYMENT_GATEWAY_VA'
);

CREATE TYPE loan_status_enum AS ENUM (
    'SUBMITTED',
    'IN_REVIEW_FRONTDESK',
    'IN_REVIEW_MANAGER',
    'WAITING_CHAIRMAN_TOKEN',
    'WAITING_ESIGN',
    'READY_FOR_DISBURSEMENT',
    'ACTIVE',
    'RESTRUCTURED',
    'PAID_OFF',
    'REJECTED'
);

CREATE TABLE loans (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    cif_id UUID NOT NULL REFERENCES member_cifs(id) ON DELETE RESTRICT,
    loan_number VARCHAR(50) UNIQUE NOT NULL, -- LN-YYYYMM-XXXXXX
    loan_type loan_type_enum NOT NULL,
    route loan_route_enum NOT NULL,
    principal_amount NUMERIC(15, 2) NOT NULL CHECK (principal_amount > 0),
    interest_rate_percent NUMERIC(5, 2) NOT NULL,
    tenor_months INT NOT NULL CHECK (tenor_months > 0),
    down_payment_amount NUMERIC(15, 2) DEFAULT 0.00,
    monthly_installment NUMERIC(15, 2) NOT NULL,
    outstanding_balance NUMERIC(15, 2) NOT NULL,
    status loan_status_enum NOT NULL DEFAULT 'SUBMITTED',
    credit_score_result JSONB NOT NULL, -- Rekam data hasil Internal Scoring Engine
    esign_document_id VARCHAR(100),
    disbursement_ref VARCHAR(100),
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
    updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
CREATE INDEX idx_loans_cif ON loans(cif_id);
CREATE INDEX idx_loans_status ON loans(status);
```

G. Tabel `loan_amortizations` (Jadwal Angsuran Pinjaman)

```
CREATE TYPE installment_status_enum AS ENUM (
    'UNPAID',
    'PAID',
    'ARREARS' -- Menunggak
);

CREATE TABLE loan_amortizations (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    loan_id UUID NOT NULL REFERENCES loans(id) ON DELETE CASCADE,
    installment_no INT NOT NULL,
    due_date DATE NOT NULL,
    principal_portion NUMERIC(15, 2) NOT NULL,
    interest_portion NUMERIC(15, 2) NOT NULL,
    total_installment NUMERIC(15, 2) NOT NULL,
    late_penalty_fee NUMERIC(15, 2) NOT NULL DEFAULT 0.00,
    paid_date TIMESTAMP WITH TIME ZONE,
    status installment_status_enum NOT NULL DEFAULT 'UNPAID',
    payment_reference VARCHAR(100),
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
CREATE INDEX idx_amort_loan ON loan_amortizations(loan_id);
CREATE INDEX idx_amort_due ON loan_amortizations(due_date, status);
```

H. Tabel `audit_logs` (Immutable WORM Audit Trail - ISO 27001)

```
CREATE TABLE audit_logs (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID REFERENCES users(id),
    ip_address INET NOT NULL,
    user_agent TEXT NOT NULL,
    module VARCHAR(50) NOT NULL, -- e.g., 'AUTH', 'LOAN_APPROVAL', 'TREASURY'
    action VARCHAR(100) NOT NULL, -- e.g., 'APPROVE_LOAN', 'DISBURSE_API'
    target_id VARCHAR(100), -- ID dari entitas yang dimodifikasi
    previous_state JSONB,
    current_state JSONB,
    status VARCHAR(20) NOT NULL, -- 'SUCCESS', 'FAILED'
    created_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP
);
-- Trigger penegakan Immutability (WORM): Mencegah UPDATE dan DELETE
CREATE OR REPLACE FUNCTION prevent_audit_log_modification()
RETURNS TRIGGER AS $$
BEGIN
    RAISE EXCEPTION 'Audit logs are immutable and cannot be updated or deleted.';
END;
$$ LANGUAGE plpgsql;

CREATE TRIGGER trg_audit_logs_immutable
BEFORE UPDATE OR DELETE ON audit_logs
FOR EACH ROW EXECUTE FUNCTION prevent_audit_log_modification();
```

3. Spesifikasi Kontrak REST API (OpenAPI Standard)

Format Respons Standar API

Seluruh respons JSON dari server wajib mengikuti format baku:

```
{
  "success": true,
  "code": 200,
  "message": "Operasi berhasil dieksekusi",
  "data": {},
  "meta": {
    "timestamp": "2026-11-07T10:00:00.000Z",
    "request_id": "req-9c8e14b3-4f91-4e76-8089-d4c5c645e7f1"
  }
}
```

Format Error Baku (OWASP Compliant — Tidak mengekspos stack trace):

```
{
  "success": false,
  "code": 400,
  "error_code": "INVALID_DEBT_RATIO",
  "message": "Pengajuan ditolak karena rasio utang melebihi batas 50%",
  "errors": [
    { "field": "monthly_installment", "message": "Cicilan melebihi kapasitas gaji bersih" }
  ],
  "meta": {
    "timestamp": "2026-11-07T10:00:00.000Z",
    "request_id": "req-9c8e14b3-4f91-4e76-8089-d4c5c645e7f1"
  }
}
```

3.1 Modul Autentikasi Mandiri & MFA

1. **`POST /api/v1/auth/register`**

- **Deskripsi:** Registrasi mandiri akun anggota baru.
- **Request Payload (Multipart/form-data):**
- `email` (string, required, format email)
- `password` (string, required, min 12 char)
- `phone_number` (string, required, format E.164)
- `full_name` (string, required)
- `nik` (string, required, 16 digit)

- `employee_id` (string, required)
- `department` (string, required)
- `ktp_file` (file binary, JPEG/PNG/PDF, max 3MB)
- `id_card_file` (file binary, max 3MB)
- `slip_gaji_file` (file binary, max 3MB)
- **Response (201 Created):**

``` { "success": true, "code": 201, "message": "Pendaftaran berhasil. Silakan verifikasi kode OTP yang dikirimkan ke email.", "data": { "user_id": "6ba7b810-9dad-11d1-80b4-00c04fd430c8", "email": "anggota@kkui.co.id", "kyc_status": "PENDING_VERIFICATION" } }

```

2. `POST /api/v1/auth/verify-otp`

- **Deskripsi:** Verifikasi token OTP email pasca registrasi.
- **Request Payload (JSON):**

``` { "user_id": "6ba7b810-9dad-11d1-80b4-00c04fd430c8", "otp_code": "849201" }

```

- **Response (200 OK):**

``` { "success": true, "code": 200, "message": "Email berhasil diverifikasi. Dokumen Anda sedang ditinjau oleh Admin Frontdesk.", "data": { "is_active": true } }

```

3. `POST /api/v1/auth/login`

- **Deskripsi:** Login kredensial mandiri dengan proteksi brute force (lockout 3x).
- **Request Payload (JSON):**

``` { "email": "anggota@kkui.co.id", "password": "PasswordKuat#2026", "captcha_token": "token-captcha-jika-diperlukan" }

```

- **Response (200 OK - Membutuhkan MFA):**

``` { "success": true, "code": 200, "message": "Kredensial valid. Silakan masukkan kode TOTP 2FA.", "data": { "mfa_required": true, "mfa_session_token": "mfa-temp-token-uuid" } }

```

4. `POST /api/v1/auth/mfa/verify`

- **Deskripsi:** Validasi token TOTP Authenticator (RFC 6238).
- **Request Payload (JSON):**

``` { "mfa_session_token": "mfa-temp-token-uuid", "totp_code": "492019" }

```

- **Response (200 OK):**
- Set-Cookie: `access_token=jwt_value; HttpOnly; Secure; SameSite=Strict; Max-Age=900; Path=/`
- Set-Cookie: `refresh_token=refresh_jwt; HttpOnly; Secure; SameSite=Strict; Max-Age=604800; Path=/api/v1/auth/refresh`

``` { "success": true, "code": 200, "message": "Login berhasil.", "data": { "user_id": "6ba7b810-9dad-11d1-80b4-00c04fd430c8", "role": "MEMBER", "cif_number": "CIF-202611-0001" } }

```

3.2 Modul Pengajuan Pinjaman & Scoring Mandiri

1. `POST /api/v1/loans/calculate-eligibility`

- **Deskripsi:** Kalkulator simulasi kredit dan penilaian awal 3 jalur risiko.
- **Headers:** `Authorization: Bearer <token>`
- **Request Payload (JSON):**

``` { "loan_type": "KREDIT_BARANG_JASA", "principal_amount": 12000000, "tenor_months": 12 }

```

```

- **Response (200 OK):**

``` { "success": true, "code": 200, "data": { "monthly_installment": 1100000.00, "debt_service_ratio": 22.4, "internal_credit_score": 88.5, "credit_grade": "A", "recommended_route": "GREEN_PAYROLL_PR23", "down_payment_required": 0.00, "can_submit": true } }

```

2. `POST /api/v1/loans/apply`

- **Deskripsi:** Submit pengajuan pinjaman resmi ke antrean LOS Backoffice.
- **Request Payload (JSON):**

``` { "loan_type": "PINJAMAN_DANA_TUNAI", "principal_amount": 10000000, "tenor_months": 12, "route": "GREEN_PAYROLL_PR23", "transaction_pin": "123456" }

```

- **Response (201 Created):**

``` { "success": true, "code": 201, "message": "Pengajuan pinjaman berhasil dibuat. Tiket Anda dalam peninjauan SLA Frontdesk.", "data": { "loan_id": "8f3d1b24-912a-43ef-b921-27814b6c891a", "loan_number": "LN-202611-000142", "status": "IN_REVIEW_FRONTDESK", "sla_deadline": "2026-11-08T10:00:00.000Z" } }

```

3.3 Modul Backoffice: Approval Center & Treasury

1. `GET /api/v1/backoffice/loans/inbox`

- **Deskripsi:** Mengambil daftar antrean SLA pengajuan pinjaman sesuai peran pengguna.
- **Headers:** `Authorization: Bearer <token>` (Admin, Manajer, Bendahara, Ketua)
- **Response (200 OK):**

``` { "success": true, "code": 200, "data": [ { "loan_id": "8f3d1b24-912a-43ef-b921-27814b6c891a", "loan_number": "LN-202611-000142", "member_name": "Ahmad Subagyo", "cif_number": "CIF-202611-0001", "loan_type": "PINJAMAN_DANA_TUNAI", "principal_amount": 10000000.00, "tenor_months": 12, "score_grade": "A", "sla_status": "GREEN_NORMAL", "hours_remaining": 18 } ] }

```

2. `POST /api/v1/backoffice/loans/:id/decision`

- **Deskripsi:** Eksekusi keputusan komite persetujuan kredit (Approve / Reject / Revise / Adjust).
- **Request Payload (JSON):**

``` { "decision": "APPROVE", "notes": "Kelayakan lolos analisis DSR dan skor kredit internal A.", "adjustment_payload": null }

```

- **Response (200 OK):**

``` { "success": true, "code": 200, "message": "Persetujuan berhasil dicatat. Status tiket berlanjut ke tahap berikutnya.", "data": { "loan_id": "8f3d1b24-912a-43ef-b921-27814b6c891a", "current_status": "WAITING_ESIGN" } }

```

3. `POST /api/v1/backoffice/treasury/disburse`

- **Deskripsi:** Eksekusi automated Bank Disbursement API untuk pencairan dana pinjaman.
- **Headers:** `Authorization: Bearer <token>` (Bendahara Treasury)
- **Request Payload (JSON):**

``` { "loan_id": "8f3d1b24-912a-43ef-b921-27814b6c891a", "dual_control_token": "token-ketua-jika-plafon-diatas-25jt" }

```

- **Response (200 OK):**

``` { "success": true, "code": 200, "message": "Pencairan dana berhasil diproses via API Bank.", "data": { "loan_id": "8f3d1b24-912a-43ef-b921-27814b6c891a", "disbursement_reference": "BANK-TRF-20261107-98412", "disbursed_amount": 10000000.00, "gl_journal_status": "SYNCED", "status": "ACTIVE" } }

```
```

4. Mekanisme Keamanan Endpoint & Middleware

1. **Autentikasi & Session:** Dikelola via JWT stateless bertenggat waktu 15 menit dengan *Refresh Token Rotation* yang tersimpan di Redis cache.
2. **Otorisasi RBAC:** Middleware server mengecek peran (`req.user.role`) pada setiap rute API. Rute `/backoffice/*` menolak secara mutlak (`403 Forbidden`) akun berstatus `MEMBER` .
3. **Pencegahan IDOR:** Setiap query database mewajibkan pencocokan ganda antara ID entitas dengan `cif_id` dari token sesi yang terautentikasi:

``` -- Aman dari manipulasi IDOR SELECT * FROM loans WHERE id = $1 AND cif_id = $2;

```

1. **Rate Limiting:** Diterapkan via Redis sliding-window algorithm:
2. Public Auth endpoint: Maksimal 10 request per menit per IP.
3. Transaksi Finansial / Submit: Maksimal 5 request per menit per User ID.
4. **Logging WORM (Write-Once-Read-Many):** Setiap eksekusi mutasi atau keputusan persetujuan memicu penulisan asynchronous ke tabel `audit_logs` sebelum respons dikirimkan ke klien.

Blueprint Keamanan Sistem, Threat Modeling & Hardening VPS

KKUI Loan Services & Member Portal

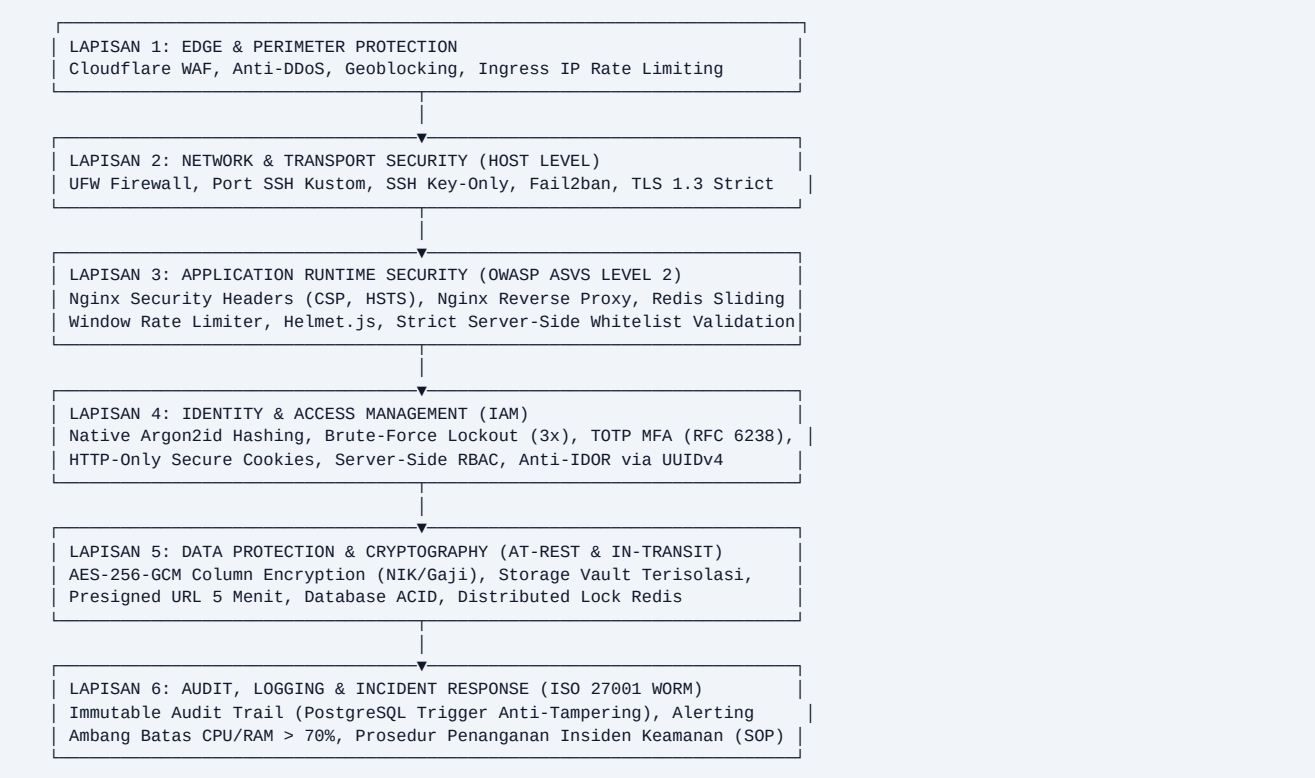
Panduan Arsitektur Keamanan Siber, Analisis Ancaman STRIDE, Standar Kepatuhan OWASP ASVS v4.0 Level 2, Kontrol ISO/IEC 27001:2022, dan SOP Hardening Server Linux

Informasi Dokumen & Tata Kelola Keamanan

- **Nama Proyek:** KKUI Loan Services & Member Portal
- **Penanggung Jawab Keamanan (Lead SecOps):** Fadhi W (PT Parvata Jingga)
- **Product Owner & Scrum Master:** Avhan HB (KKUI)
- **Tim Pengembang (Engineering):** Fahmy & Mike (PT Parvata Jingga)
- **Status Dokumen:** Baseline Security Version 1.0 (Approved for Sprint 1-6)
- **Tanggal Berlaku:** 7 November 2026
- **Klasifikasi Dokumen:** Sangat Rahasia (*Strictly Confidential - Internal Tech & Security Team*)
- **Standar Acuan Utama:**
- **OWASP Top 10 (2021) & OWASP ASVS v4.0 Level 2** (Financial Services Application Verification)
- **ISO/IEC 27001:2022** (Information Security Management System - ISMS Controls A.5, A.6, A.8)
- **ISO/IEC 27701:2019 & UU No. 27 Tahun 2022** (Pelindungan Data Pribadi / PDP)
- **CIS Linux Benchmark v2.0** (Ubuntu 24.04 LTS Server Benchmark Level 1)

1. Prinsip Dasar & Arsitektur Keamanan Berlapis (Defense-in-Depth)

Keamanan KKUI Loan Services Portal dirancang dengan pendekatan **Zero Trust & Defense-in-Depth**, di mana tidak ada satu lapisan pun yang dipercaya secara *default*.



2. Pemodelan Ancaman (STRIDE Threat Modeling)

Analisis ancaman dilakukan terhadap alur fungsional kritis (Pendaftaran Anggota, Autentikasi, Pengajuan Pinjaman, Mesin Scoring Mandiri, dan Pencairan Treasury):

Kategori STRIDE	Potensi Ancaman pada Portal KKUI	Dampak Bisnis / Keamanan	Kontrol Mitigasi Wajib (Arsitektur & Kode)	Tanggung Jawab
Spoofing (Pemalsuan Identitas)	Penyerang memalsukan identitas anggota lain saat login atau mendaftar menggunakan NIK curian.	Akses ilegal ke rekening simpanan dan pengajuan pinjaman fiktif.	• Hashing password adaptif **Argon2id**. • Wajib verifikasi OTP email (token acak 6 digit, kedaluwarsa 5 menit). • Enrolment **MFA TOTP RFC 6238** (Google Authenticator). • Pengecekan silang ID Karyawan & Slip Gaji manual oleh Admin Frontdesk.	Fahmy & Fadhi W
Tampering (Manipulasi Data)	Calon debitur mengubah nominal gaji, nilai cicilan, atau skor kelayakan kredit di sisi frontend/browser sebelum submit.	Persetujuan kredit fiktif / macet melebihi batas DSR yang aman.	• 100% kalkulasi kelayakan dan DSR dilakukan di sisi server (*Node.js Core Scoring Service*). • Data gaji divalidasi ulang terhadap berkas slip gaji tersimpan. • Integritas file payroll HRD diverifikasi menggunakan **Checksum SHA-256**. • Pencegahan SQL Injection menggunakan parameterized query ORM.	Mike & Fahmy
Repudiation (Penyangkalan Aksi)	Staf backoffice menyetujui pinjaman kerabat secara ilegal lalu menyangkal telah melakukan approval.	Fraud internal dan kerugian kas koperasi.	• Implementasi **Immutable Audit Trail (WORM)** pada tabel `audit_logs`. • Database trigger PostgreSQL mencegah mutasi/penghapusan log (`BEFORE UPDATE OR DELETE RAISE EXCEPTION`). • Pencatatan identitas user, IP address, user-agent, dan diff state (sebelum/sesudah).	Fadhi W & Mike
Information Disclosure (Kebocoran Data)	Penyerang mengakses foto KTP, slip gaji, atau data NIK anggota melalui tebakan URL direktori (*Path Traversal* / IDOR).	Pelanggaran berat UU PDP (Denda regulasi) dan pencurian identitas.	• Berkas KTP/slip gaji disimpan di luar web root server (`/var/storage/kkui/vault/`). • Akses berkas hanya dapat dibuka melalui **Presigned URL berumur 5 menit**. • Kolom NIK dan data rekening bank dienkripsi **AES-256-GCM** di database. • Penghapusan seluruh rincian stack trace error pada respons JSON API.	Fadhi W & Mike
Denial of Service (Penolakan Layanan)	Penyerang membanjiri endpoint login atau pencairan dana dengan request masif (DDoS / Brute Force).	Layanan koperasi lumpuh dan server VPS down.	• Cloudflare Anti-DDoS dan Nginx ingress rate limiter. • **Redis Sliding-Window Rate Limiter**: Maksimal 10 req/menit untuk login, 5 req/menit untuk transaksi finansial. • **Account Lockout**: Akun terkunci otomatis 15 menit jika salah kata sandi 3x berturut-turut + tantangan CAPTCHA. • Monitoring utilisasi CPU/RAM dengan alert otomatis jika beban > 70%.	Fadhi W

Kategori STRIDE	Potensi Ancaman pada Portal KKUI	Dampak Bisnis / Keamanan	Kontrol Mitigasi Wajib (Arsitektur & Kode)	Tanggung Jawab
Elevation of Privilege (Eskalasi Wewenang)	Anggota biasa memanggil endpoint approval backoffice (`/api/v1/backoffice/loans/:id/decision`) atau merubah peran menjadi Manager/Admin.	Pencairan dana ilegal dan pengambilalihan kontrol sistem.	• Middleware otorisasi server-side mengecek token JWT dan tabel `roles_permissions` pada setiap request. • Rute `/backoffice/*` menolak mutlak role `MEMBER` (`403 Forbidden`). • Otorisasi ganda (**Dual Control Token**) Ketua Koperasi untuk pencairan > Rp25 jt. • Penegakan prinsip *Least Privilege* (ISO 27001 Control A.5.15).	Fahmy, Mike & Fadhi W

3. Matriks Kepatuhan OWASP ASVS v4.0 Level 2

Sesuai standar aplikasi finansial, tim pengembang menerapkan kriteria verifikasi berikut:

Kode ASVS	Domain Keamanan	Persyaratan Teknis	Implementasi pada KKUI Portal
V1	Arsitektur & Threat Modeling	Pemodelan ancaman, pemisahan modul otonom, dan kedaulatan data tanpa ketergantungan pihak ketiga.	Clean Architecture Modular Monolith, penolakan SSO eksternal/e-KYC vendor luar, dan isolasi storage.
V2	Autentikasi & Sandi	Kebijakan password kuat, algoritma hashing adaptif, dan proteksi serangan *credential stuffing*.	Minimal 12 karakter (kombinasi 4 jenis karakter); algoritma **Argon2id** (memory=64MB, iterations=3, parallelism=4); lockout 3x gagal; MFA TOTP RFC 6238.
V3	Manajemen Sesi	Pembuatan, penyimpanan, dan pemusnahan sesi yang aman dari pembajakan (*Session Hijacking*).	JWT stateless bertenggat 15 menit tersimpan pada **HTTP-Only, Secure, SameSite=Strict Cookies**; Refresh Token Rotation di Redis; auto-logout saat idle.
V4	Kontrol Akses (Access Control)	Pencegahan eskalasi hak akses dan manipulasi direct object reference (IDOR).	Seluruh Primary Key menggunakan UUIDv4 acak; query database mewajibkan validasi kepemilikan data (`WHERE id = $1 AND cif_id = $2`); penegakan RBAC di sisi server.
V5	Validasi Input & Sanitasi	Validasi ketat format input di server (whitelist) dan pencegahan injeksi kode jahat.	Validasi skema request menggunakan Zod/Joi di layer controller; sanitasi string anti-XSS (DOMPurify/sanitize-html); 100% parameterized query PostgreSQL (anti-SQLi).
V8	Kriptografi Data	Enkripsi data rahasia saat diam (*at-rest*) dan saat berpindah (*in-transit*).	TLS 1.3 wajib pada seluruh trafik; enkripsi simetris **AES-256-GCM** dengan IV acak unik per baris pada kolom NIK dan slip gaji; kunci KMS terisolasi di server.
V14	Konfigurasi Server & Header	Pengerasan konfigurasi server aplikasi dan penambahan security headers.	Nginx security headers: CSP ketat, HSTS, X-Content-Type-Options: nosniff, X-Frame-Options: DENY, Referrer-Policy: strict-origin-when-cross-origin.

4. Playbook Hardening Server Linux VPS (Ubuntu 24.04 LTS)

Panduan operasional konfigurasi server bagi **Fadhi W** untuk memastikan server VPS 4 vCPU / 8 GB RAM kebal terhadap serangan eksternal.

4.1 Pengerasan Akses SSH & Akun Sistem

1. **Nonaktifkan Login Root & Password Authentication:**
2. Edit `/etc/ssh/sshd_config` : `bash Port 2222 # Mengubah default port 22 ke port kustom PermitRootLogin no # Melarang login langsung menggunakan user root PasswordAuthentication no # Mewajibkan otentikasi SSH Key PubkeyAuthentication yes MaxAuthTries 3 # Maksimal 3 kali percobaan autentikasi ClientAliveInterval 300 # Timeout otomatis sesi SSH yang tidak aktif ClientAliveCountMax 0`
3. Restart layanan: `sudo systemctl restart sshd`
4. **Akun Pengelola Terpisah:**
5. Menggunakan akun sudo non-root khusus (`devops-kkui`) dan mengunci akses user `ubuntu` / `root` .

4.2 Konfigurasi Firewall UFW & Intrusion Prevention (Fail2ban)

1. **Firewall UFW (Uncomplicated Firewall):** `bash sudo ufw default deny incoming sudo ufw default allow outgoing sudo ufw allow 2222/tcp comment 'Custom SSH Port' sudo ufw allow 80/tcp comment 'Nginx HTTP for Certbot' sudo ufw allow 443/tcp comment 'Nginx HTTPS TLS 1.3' sudo ufw enable`
2. **Fail2ban untuk Proteksi Brute-Force SSH & HTTP:**
3. Konfigurasi `/etc/fail2ban/jail.local`: ```ini [sshd] enabled = true port = 2222 filter = sshd logpath = /var/log/auth.log maxretry = 3 bantime = 1d findtime = 10m

   [nginx-req-limit] enabled = true filter = nginx-limit-req logpath = /var/log/nginx/error.log maxretry = 5 bantime = 1h ```

4.3 Konfigurasi Nginx Reverse Proxy & TLS 1.3 Hardening

File konfigurasi `/etc/nginx/sites-available/kkui-portal.conf`:

```
# Rate Limiting Zones
limit_req_zone $binary_remote_addr zone=auth_limit:10m rate=10r/m;
limit_req_zone $binary_remote_addr zone=api_limit:10m rate=30r/m;

server {
    listen 80;
    server_name portal.kkui.co.id;
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl http2;
    server_name portal.kkui.co.id;

    # SSL / TLS 1.3 Protocols & Ciphers (Mozilla Modern Standard)
    ssl_certificate /etc/letsencrypt/live/portal.kkui.co.id/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/portal.kkui.co.id/privkey.pem;
    ssl_protocols TLSv1.3;
    ssl_prefer_server_ciphers off;
    ssl_session_timeout 1d;
    ssl_session_cache shared:SSL:10m;
    ssl_session_tickets off;

    # Security Headers (OWASP Recommended)
    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-Frame-Options "DENY" always;
    add_header X-XSS-Protection "1; mode=block" always;
    add_header Referrer-Policy "strict-origin-when-cross-origin" always;
    add_header Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'sel
f' data:; font-src 'self'; connect-src 'self'; frame-ancestors 'none';" always;

    # Max Payload Upload (KTP & Slip Gaji maks 3 MB)
    client_max_body_size 5M;

    # Frontend Next.js Proxy
    location / {
        proxy_pass http://127.0.0.1:3000;
        proxy_http_version 1.1;
        proxy_set_header Upgrade $http_upgrade;
        proxy_set_header Connection 'upgrade';
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }

    # Backend API Proxy with Rate Limiter
    location /api/v1/auth/ {
        limit_req zone=auth_limit burst=5 nodelay;
        proxy_pass http://127.0.0.1:5000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }

    location /api/v1/ {
        limit_req zone=api_limit burst=10 nodelay;
        proxy_pass http://127.0.0.1:5000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }

    # Deny Access to Hidden Files (.git, .env)
    location ~ /\. {
```

```
        deny all;
        access_log off;
        log_not_found off;
    }
}
```

4.4 Pengerasan Basis Data PostgreSQL 16 & Redis

1. **PostgreSQL Network Binding:**
2. Diatur hanya mendengarkan loopback lokal (`listen_addresses = 'localhost'` pada `postgresql.conf`). Port 5432 tidak pernah dibuka ke internet.
3. **Koneksi Aplikasi Terisolasi:**
4. Aplikasi menggunakan akun `kkui_app` dengan hak akses terbatas pada schema publik (tanpa hak `SUPERUSER`).
5. **Redis Security:**
6. Diatur hanya mendengarkan `127.0.0.1` pada port 6379 dengan proteksi kata sandi kuat (`requirepass <Random-64-Char-String>`).
7. Perintah berbahaya dinonaktifkan: `rename-command FLUSHALL ""` dan `rename-command CONFIG ""` .

---

5. Pipeline DevSecOps CI/CD (Automated Security Gates)

Pada alur pengembangan Agile dua mingguan, setiap commit dan Pull Request (PR) yang diajukan oleh **Fahmy** atau **Mike** wajib melewati gerbang keamanan otomatis di GitHub Actions yang dikonfigurasi oleh **Fadhi W**:

```
 [ Developer Git Push (feature/US-xx) ]
                  |
                  ▼
[ GitHub Actions CI/CD Pipeline ]
  ├─ 1. Secret Detection (TruffleHog): Deteksi kebocoran API key / kredensial
  ├─ 2. SAST Code Scan (Semgrep): Pemindaian kerentanan kode OWASP Top 10
  ├─ 3. Dependency Audit (npm audit / Snyk): Deteksi celah pada paket library pihak ketiga
  ├─ 4. Container Scan (Trivy): Pemindaian CVE pada base image Docker Ubuntu/Node
  └─ 5. Automated Unit & Integration Tests (Jest / Supertest): Code coverage >= 80%
                  |
           (Lulus 100%)
                  ▼
[ Peer Code Review ] (Fahmy <-> Mike)
                  |
                  ▼
[ Security Review & DAST Scan ] (Fadhi W via OWASP ZAP Baseline)
                  |
                  ▼
[ Merge to Staging Server on Linux VPS ]
```

- **Aturan Kegagalan CI/CD (Build Breaker):** Jika ditemukan kerentanan dengan tingkat keparahan **CRITICAL** atau **HIGH** pada hasil scan Semgrep, Trivy, atau TruffleHog, pipeline otomatis berhenti (*exit code 1*) dan Pull Request ditolak secara otomatis hingga developer memperbaikinya.

---

6. Prosedur Audit Trail & Manajemen Insiden Siber (ISO 27001)

6.1 Tata Kelola Audit Log WORM (ISO 27001 Control A.8.15)

1. **Spesifikasi Event yang Wajib Dicatat:**
2. Seluruh percobaan login (sukses maupun gagal).
3. Perubahan kata sandi, pengaturan MFA, dan reset akun.
4. Perubahan status verifikasi KYC pendaftaran anggota.
5. Setiap keputusan komite kredit (Approve, Reject, Revise, Adjustment).
6. Eksekusi transfer pencairan dana pinjaman via Bank API.
7. Unggah file hasil potongan payroll HRD dan eksekusi rekonsiliasi.
8. **Atribut Rekam Jejak Log:**
9. `timestamp` (UTC ISO-8601), `user_id` , `role` , `ip_address` , `user_agent` , `action_code` , `target_entity_id` , `diff_state_json` , dan `execution_status` .
10. **Penyimpanan & Retensi:**
11. Log disimpan pada tabel terproteksi `audit_logs` dan diekspor harian ke penyimpanan arsip *offsite* terenkripsi dengan masa retensi minimal **5 tahun** sesuai regulasi audit keuangan koperasi.

6.2 Standar Operasional Prosedur (SOP) Penanganan Insiden Keamanan (ISO 27001 Control A.8.16)

```
[ TAHAP 1: DETEKSI & IDENTIFIKASI ]
  • Pemicu: Alert WAF, Fail2ban alert, anomali beban CPU > 70%, atau laporan staf.
  • Tindakan: Fadhi W melakukan verifikasi awal jenis serangan (DDoS, brute force, atau SQLi).

[ TAHAP 2: ISOLASI & PENAHANAN (CONTAINMENT) ]
  • Jika serangan IP eksternal: Blokir IP pada level Cloudflare WAF dan UFW firewall.
  • Jika anomali akun: Bekukan sementara akun yang terindikasi disusupi via database (`is_active = FALSE`).
  • Jika kebocoran data: Cabut segera kredensial API eksternal (Bank/Payment Gateway) dan generate secret baru.

[ TAHAP 3: REMEDIASI & ERADIKASI ]
  • Tim pengembang (Fahmy & Mike) bersama Fadhi W mengidentifikasi celah kode (*root cause analysis*).
  • Penerapan patch darurat pada branch hotfix dan pengujian instan pada pipeline SAST.
  • Deploy patch ke server VPS staging dan production.

[ TAHAP 4: PEMULIHAN (RECOVERY) ]
  • Verifikasi integritas data transaksi pada PostgreSQL menggunakan snapshot cadangan terakhir.
  • Mengaktifkan kembali layanan penuh dan memantau log lalu lintas secara intensif selama 24 jam.

[ TAHAP 5: PELAPORAN & EVALUASI PASCA-INSIDEN ]
  • Fadhi W menyusun Incident Post-Mortem Report untuk diserahkan ke Avhan HB (PO) dan Pengurus Koperasi.
  • Memperbarui aturan firewall, filter WAF, dan skenario pengujian regresi untuk mencegah insiden berulang.
```

---

7. Checklist Kesiapan Keamanan Pra-Go-Live (*Security Sign-Off*)

Sebelum sistem dinyatakan siap melayani 300 anggota pada tahap Go-Live, seluruh item berikut wajib diverifikasi dan ditandatangani oleh **Fadhi W** (*Cyber Security Lead*):

- [ ] **Kerahasiaan Berkas Anggota:** Direktori upload KTP dan slip gaji terisolasi di luar web root, berstatus hak akses `chmod 700`, dan terbukti tidak bisa diakses langsung via URL browser.
- [ ] **Enkripsi Database Berfungsi:** Verifikasi query langsung ke database membuktikan kolom NIK dan data rekening tersimpan dalam format ciphertext acak (AES-256-GCM).
- [ ] **MFA TOTP Berjalan Lancar:** Verifikasi login staf dan anggota berhasil meminta token authenticator 6 digit dan kode darurat cadangan berfungsi.
- [ ] **Simulasi Brute Force Lulus:** Percobaan login salah kata sandi 3 kali berturut-turut terbukti mengunci akun selama 15 menit dan memicu alert keamanan.
- [ ] **IDOR Testing Clear:** Percobaan manipulasi parameter `id` pinjaman anggota A menggunakan token sesi anggota B menghasilkan respons `404 Not Found` atau `403 Forbidden`.
- [ ] **Port Scanner Nmap Audit:** Pemindaian Nmap eksternal membuktikan hanya port 80/443 dan port kustom SSH 2222 yang terbuka; port database PostgreSQL (5432) dan Redis (6379) tertutup rapat.
- [ ] **Audit Trail WORM Teruji:** Eksekusi perintah `UPDATE audit_logs SET action = 'test'` pada PostgreSQL terbukti gagal dan memunculkan pesan error trigger database.
- [ ] **Offsite Backup Otomatis Terverifikasi:** Dump database terbukti sukses diunggah ke storage offsite cadangan dan berhasil diuji coba pemulihan (*restore test*).

Rencana Pengujian, Uji Penetrasi & Panduan UAT

KKUI Loan Services & Member Portal

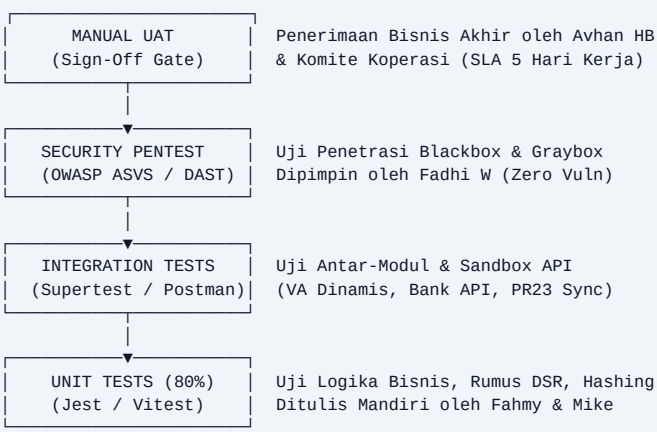
Master Test Plan, Security Penetration Testing Methodology (OWASP ASVS), Functional Test Cases, and User Acceptance Testing (UAT) Sign-Off Framework

Informasi Dokumen

- **Proyek:** KKUI Loan Services & Member Portal
- **Product Owner & Scrum Master:** Avhan HB (KKUI)
- **Lead Fullstack Developer:** Fahmy (PT Parvata Jingga)
- **Core & Backoffice Developer:** Mike (PT Parvata Jingga)
- **Lead Quality & Security Assessor:** Fadhi W (PT Parvata Jingga)
- **Status Dokumen:** Baseline QA & Security Testing Version 1.0
- **Tanggal Berlaku:** 7 November 2026
- **Standar Pengujian:** OWASP Top 10 (2021), OWASP ASVS v4.0 Level 2, ISO/IEC 27001:2022, ISO/IEC/IEEE 29119 Software Testing

1. Strategi & Piramida Pengujian (Test Strategy)

Pengujian kualitas pada KKUI Loan Services Portal dirancang berlapis menggunakan piramida pengujian terotomasi dan manual untuk menjamin keandalan sistem finansial bagi 300 anggota.



Kriteria Kelulusan Pengujian (Entry & Exit Criteria)

1. **Entry Criteria (Syarat Mulai Pengujian):**
2. Seluruh kode fitur telah di-merge ke branch staging dan lolos build CI/CD tanpa kegagalan unit test.
3. Tidak ada kegagalan pemindaian dependensi otomatis (SAST Semgrep & Container Trivy).
4. Data master, formula bunga, penalti SISKA 1,5%, dan simulasi gaji telah tersedia di staging database.
5. **Exit Criteria (Syarat Kelulusan Rilis):**
6. **Unit & Integration Test:** Code coverage minimal 80% pada modul finansial inti.
7. **Security Testing: 0 Defect** pada kategori *Critical* dan *High* berdasarkan OWASP Top 10.
8. **UAT Acceptance:** 100% skenario pengujian bisnis utama berstatus *PASS* dan Berita Acara UAT ditandatangani oleh Product Owner (**Avhan HB**).

2. Matriks Kasus Uji Fungsional (Functional Test Cases)

Berikut adalah skenario pengujian fungsional kritis mencakup kasus positif dan kasus negatif:

2.1 Modul Autentikasi Mandiri & Onboarding

ID Kasus Uji	Modul / Fitur	Skenario Pengujian	Langkah & Input Data	Hasil yang Diharapkan	Status
TC-AUTH-01	Registrasi	Pendaftaran mandiri dengan data valid (Kasus Positif)	Input email perusahaan, nomor WhatsApp, NIK 16 digit, password kuat (12 char), upload KTP & slip gaji (format PDF/JPEG < 3 MB).	Akun terdaftar berstatus `PENDING_VERIFICATION`, kode OTP 6 digit terkirim ke email, dokumen tersimpan di vault terenkripsi.	Pass
TC-AUTH-02	Registrasi	Validasi password lemah (Kasus Negatif)	Input password 8 karakter tanpa kombinasi simbol/angka (`password123`).	Sistem menolak registrasi (`400 Bad Request`) dengan pesan kesalahan kebijakan password OWASP.	Pass
TC-AUTH-03	Verifikasi OTP	Verifikasi kode OTP kedaluwarsa (Kasus Negatif)	Memasukkan kode OTP setelah melewati batas waktu 5 menit.	Sistem menolak kode OTP (`400 Token Expired`) dan menawarkan pengiriman ulang kode baru.	Pass
TC-AUTH-04	Login	Login kredensial valid & MFA TOTP (Kasus Positif)	Memasukkan email, password benar, dan 6 digit token dari Google Authenticator.	Login sukses, server mengirim cookie HTTP-only Secure, halaman redirect ke Dashboard Anggota.	Pass
TC-AUTH-05	Login	Proteksi Brute-force Account Lockout (Kasus Negatif)	Memasukkan password salah 3 kali berturut-turut pada akun yang sama.	Akun otomatis terkunci selama 15 menit, percobaan ke-4 ditolak (`423 Locked`), audit log mencatat percobaan brute force.	Pass

2.2 Modul Simpanan & Investasi (Pemisahan Modul)

ID Kasus Uji	Modul / Fitur	Skenario Pengujian	Langkah & Input Data	Hasil yang Diharapkan	Status
TC-SIMP-01	Simpanan Pokok	Unduh e-Sertifikat Keanggotaan (Kasus Positif)	Anggota aktif berstatus *Approved* mengklik tombol "Unduh Sertifikat".	Terbit file PDF resmi ber-watermark dinamis NIK anggota dan QR Code verifikasi integritas data.	Pass
TC-SIMP-02	Iuran Wajib	Deteksi status iuran bulanan menunggak (Kasus Negatif)	Anggota tidak memiliki rekam potongan iuran wajib pada bulan berjalan.	Dasbor menampilkan status merah "Menunggak" dengan rincian nominal dan tombol bayar via VA Dinamis.	Pass
TC-SIMP-03	Simpanan Investasi	Top-up modal investasi via VA (Kasus Positif)	Anggota membuat tagihan top-up Rp5.000.000, lalu melakukan simulasi pembayaran webhook Midtrans/Xendit.	Saldo Investasi bertambah Rp5.000.000, mutasi kredit tercatat di buku besar, proyeksi dividen SHU ter-update.	Pass
TC-SIMP-04	Simpanan Sukarela	Penarikan dana melebihi saldo tersedia (Kasus Negatif)	Saldo sukarela Rp2.000.000, anggota mengajukan penarikan Rp3.000.000.	Transaksi ditolak sistem (`400 Insufficient Funds`) sebelum masuk ke antrean approval.	Pass
TC-SIMP-05	SISKA Berjangka	Pencairan awal sebelum jatuh tempo (Early Break)	Deposito Rp10.000.000 tenor 6 bulan dicairkan pada bulan ke-2 (Kasus Khusus).	Kalkulator memotong penalti 1,5% (Rp150.000), nominal cair Rp9.850.000 masuk antrean persetujuan Manajer.	Pass

2.3 Modul Pinjaman & Mesin Scoring Kredit Mandiri

ID Kasus Uji	Modul / Fitur	Skenario Pengujian	Langkah & Input Data	Hasil yang Diharapkan	Status
TC-LOAN-01	Scoring Mandiri	Pengajuan Jalur Hijau (DSR < 33% & Skor A)	Gaji bersih Rp10.000.000, cicilan baru Rp2.000.000 (DSR 20%), histori KKUI bersih 12 bulan.	Sistem mengklasifikasikan Skor A, merekomendasikan Jalur Hijau (Payroll PR23, DP 0%), form langsung submit.	Pass
TC-LOAN-02	Scoring Mandiri	Pengajuan Jalur Kuning (DSR 33%–50% & Skor B)	Gaji bersih Rp8.000.000, cicilan Rp3.200.000 (DSR 40%), saldo sukarela Rp8.000.000 (> 2x cicilan).	Sistem mengarahkan ke Jalur Kuning (Auto-debet Sukarela), saldo cadangan tervalidasi memenuhi syarat.	Pass

ID Kasus Uji	Modul / Fitur	Skenario Pengujian	Langkah & Input Data	Hasil yang Diharapkan	Status
TC-LOAN-03	Scoring Mandiri	Penolakan Rasio Utang Ekstrem (DSR > 65%)	Gaji bersih Rp6.000.000, cicilan diajukan Rp4.500.000 (DSR 75%).	Sistem otomatis menolak pengajuan (`400 Debt Ratio Exceeded`) dan menyarankan restrukturisasi atau perpanjangan tenor.	Pass
TC-LOAN-04	Akad Kredit	Penandatanganan Akad Digital e-Sign	Debitur membuka dokumen perjanjian PDF yang diterbitkan dan membubuhkan tanda tangan e-Sign tersertifikasi.	Webhook e-Sign menerima status valid, tiket pinjaman otomatis berpindah status ke `READY_FOR_DISBURSEMENT` .	Pass

2.4 Modul Backoffice & Rekonsiliasi Payroll PR23

ID Kasus Uji	Modul / Fitur	Skenario Pengujian	Langkah & Input Data	Hasil yang Diharapkan	Status
TC-BO-01	LOS Approval	Approval kredit di atas limit tanpa token Ketua (Kasus Negatif)	Bendahara mencoba menyetujui pencairan pinjaman Rp30.000.000 tanpa input token otorisasi Ketua Koperasi.	Sistem memblokir eksekusi (`403 Dual Authorization Required`) sesuai batas matriks limit > Rp25 jt.	Pass
TC-BO-02	Treasury	Pencairan dana saat saldo buffer bank tidak cukup	Saldo buffer penampung Rp5.000.000, nominal pinjaman disetujui Rp10.000.000.	API menahan transfer, status tiket `BUFFER_INSUFFICIENT` , notifikasi peringatan terkirim ke WhatsApp Bendahara.	Pass
TC-BO-03	Payroll PR23	Unggah file potongan HRD dengan manipulasi hash (Kasus Negatif)	Mengunggah file CSV payroll yang checksum SHA-256-nya tidak cocok dengan manifest pengiriman.	Parser membatalkan proses import (`422 File Integrity Failed`) dan mencatat insiden integritas berkas.	Pass
TC-BO-04	Payroll PR23	Auto-Rekonsiliasi potongan gaji sukses & selisih	Mengunggah data 10 anggota: 9 sukses terpotong penuh, 1 anggota terpotong sebagian (kurang).	9 rekening ter-update Lunas; 1 rekening tercatat menunggak (*arrears*), jurnal GL terposting tanpa selisih manual.	Pass

3. Metodologi Uji Penetrasi Keamanan (Security Pentest - OWASP ASVS)

Uji penetrasi keamanan dilakukan secara komprehensif oleh **Fadhi W** (*Lead SecOps*) menggunakan pendekatan *Graybox Testing* pada lingkungan staging Linux VPS:

```
 [ TAHAP PENTEST 1: RECONNAISSANCE & PORT AUDIT ]
   • Alat: Nmap, WhatWeb
   • Target: Memastikan hanya port 80/443 dan 2222 yang terbuka; port 5432 (Postgres) dan 6379 (Redis) tertutup.

 [ TAHAP PENTEST 2: AUTOMATED VULNERABILITY SCANNING ]
   • Alat: OWASP ZAP (DAST Baseline Scan), Semgrep (SAST), Trivy (Container Scan)
   • Target: Mengidentifikasi kerentanan konfigurasi Nginx headers, cross-site scripting, dan CVE library.

 [ TAHAP PENTEST 3: MANUAL EXPLOITATION (OWASP TOP 10 FOCUS) ]
   • A01 Broken Access Control: Simulasi serangan IDOR antar-anggota & eskalasi role privilege.
   • A02 Cryptographic Failures: Audit enkripsi kolom NIK database dan kelemahan cipher TLS.
   • A03 Injection: Pengujian SQL Injection payload pada kolom pencarian katalog dan filter mutasi.
   • A07 Identification & Authentication: Pengujian bypass MFA TOTP dan brute-force token OTP email.

 [ TAHAP PENTEST 4: REPORTING & REMEDIATION VERIFICATION ]
   • Penyusunan laporan temuan kerentanan (Severity: Critical, High, Medium, Low).
   • Verifikasi perbaikan kode bersama Fahmy & Mike hingga seluruh temuan Critical/High berstatus CLOSED.
```

Matriks Skenario Uji Penetrasi Khusus (Security Test Cases)

ID Uji Keamanan	Kategori OWASP	Skenario Serangan / Eksploitasi	Prosedur Pengujian Teknis	Kriteria Lolos (Security Gate)
SEC-TEST-01	A01: Broken Access Control	**Serangan IDOR pada Data Pinjaman:** Debitur A mencoba melihat rincian pinjaman Debitur B dengan mengganti parameter UUID pada endpoint `/api/v1/loans/:id`.	Intercept request menggunakan Burp Suite / Postman, ubah `loan_id` milik user lain dengan bearer token user aktif.	Server merespons `404 Not Found` atau `403 Forbidden`. Tidak ada data pinjaman orang lain yang bocor.
SEC-TEST-02	A01: Broken Access Control	**Eskalasi Wewenang ke Endpoint Backoffice:** Akun berstatus `MEMBER` mencoba menembak langsung endpoint persetujuan pinjaman `/api/v1/backoffice/loans/:id/decision`.	Kirim request POST approval menggunakan token JWT anggota biasa.	Server memblokir akses secara mutlak (`403 Forbidden`) dan mencatat percobaan eskalasi ke audit log.
SEC-TEST-03	A02: Cryptographic Failures	**Akses Langsung Berkas KTP (Direct Object Access):** Penyerang mencoba mengunduh dokumen KTP anggota via URL statis browser tanpa token autentikasi.	Akses URL tebakan seperti `https://portal.kkui.co.id/storage/ktp/user-123.jpg`.	Nginx menolak akses (`404 Not Found`). Berkas hanya bisa dibuka lewat Presigned URL bertenggat 5 menit.
SEC-TEST-04	A03: Injection	**SQL Injection pada Filter Katalog & Mutasi:** Penyerang memasukkan payload SQLi klasik (`' OR 1=1 --`) pada parameter pencarian nama barang atau filter tanggal mutasi.	Inject payload SQLi pada parameter query `GET /api/v1/catalog?search=' OR 1=1 --`.	Query diproses sebagai literal string oleh parameterized query ORM. Nol error database syntax yang terekspos.
SEC-TEST-05	A07: Auth Failures	**Bypass Verifikasi MFA TOTP:** Penyerang mencoba mengakses endpoint terproteksi setelah memasukkan password tanpa mengirimkan validasi token TOTP.	Panggil endpoint private menggunakan `mfa_session_token` sementara tanpa memanggil `/mfa/verify`.	Server menolak permintaan (`401 Unauthorized - MFA Verification Required`). Sesi penuh belum terbit.
SEC-TEST-06	A08: Integrity Failures	**Manipulasi Audit Log Database (WORM Tampering):** Penyerang dengan akses database mencoba mengubah atau menghapus baris pada tabel `audit_logs`.	Jalankan query SQL: `DELETE FROM audit_logs WHERE module = 'TREASURY';`.	Trigger database PostgreSQL membatalkan transaksi dan memicu exception: *Audit logs are immutable*.

4. Panduan & Skenario UAT (*User Acceptance Testing*)

UAT merupakan validasi bisnis akhir yang dilakukan oleh pengguna riil dan perwakilan pengurus koperasi yang dipimpin oleh **Avhan HB** (*Product Owner*).

4.1 Prosedur Pelaksanaan UAT

1. **Lingkungan UAT:** Server Staging Linux VPS terisolasi dengan konfigurasi identik production (`staging-portal.kkui.co.id`).
2. **Durasi Pelaksanaan:** 5 hari kerja (Fase 9 sebelum cut-off deployment production).
3. **Peserta Penguji UAT:**
4. **Avhan HB** (Product Owner & Scrum Master - Penanggung Jawab UAT)
5. Perwakilan Anggota Koperasi (2 orang debitur uji coba)
6. Admin Frontdesk Koperasi (1 orang staf operasional)
7. Manajer Operasional Koperasi (1 orang verifikator kredit)
8. Bendahara Treasury (1 orang pengeksekusi kas)
9. **Data Uji Coba (Test Data Mocking):**
10. 10 akun anggota dengan variasi gaji bersih (Rp4 jt s/d Rp15 jt).
11. Data simulasi pemotongan gaji HRD (PR23) dengan kasus lunas dan menunggak.
12. Akun sandbox Payment Gateway (VA Dinamis) dan Sandbox Bank Disbursement.

4.2 Skenario Bisnis End-to-End (UAT Test Scripts)

```
[ SKENARIO BISNIS 1: ONBOARDING & PEMBUKAAN REKENING BARU ]
  1. Calon anggota mendaftar mandiri via web browser HP -> Unggah KTP & Slip Gaji.
  2. Input kode OTP email -> Akun aktif dengan status Pending Verification.
  3. Admin Frontdesk membuka antrean KYC -> Periksa kesesuaian KTP via temporary viewer.
  4. Manajer Operasional menyetujui -> Nomor CIF & Akun Simpanan otomatis terbit.
  5. Anggota login -> Tampilan portofolio Simpanan Pokok & tombol unduh e-Sertifikat aktif.
  -> Kriteria Keberhasilan: Nomor CIF terbit otomatis, e-Sertifikat QR valid.

[ SKENARIO BISNIS 2: PENGAJUAN KREDIT BARANG & JASA (E-KATALOG) JALUR HIJAU ]
  1. Anggota memilih produk elektronik di e-Katalog koperasi (Nilai Rp6.000.000, Tenor 6 bulan).
  2. Sistem menjalankan scoring mandiri -> DSR terhitung 22% (Skor A / Jalur Hijau).
  3. Anggota submit pengajuan dengan memasukkan PIN transaksi 6 digit.
  4. Tiket masuk ke inbox SLA Backoffice -> Disetujui bertingkat oleh Admin & Manajer.
  5. Notifikasi WhatsApp terkirim ke Anggota -> Anggota menandatangani akad e-Sign.
  6. Bendahara memverifikasi e-Sign -> Eksekusi pencairan via Bank Disbursement API.
  -> Kriteria Keberhasilan: Dana/PO terbit, SLA tuntas < 24 jam, jadwal angsuran terbentuk.

[ SKENARIO BISNIS 3: REKONSILIASI POTONGAN GAJI PAYROLL PR23 AKHIR BULAN ]
  1. Bendahara men-generate file cut-off tagihan bulanan format Excel/CSV dari sistem.
  2. File diserahkan ke bagian HRD untuk eksekusi pemotongan gaji karyawan.
  3. Bendahara mengunggah file balikan payroll dari HRD ke portal Backoffice KKUI.
  4. Sistem mencocokkan nomor induk karyawan -> 95% lunas otomatis, 5% gagal potong.
  5. Sistem otomatis memposting jurnal pelunasan ke buku besar (GL) dan mencatat denda.
  -> Kriteria Keberhasilan: Rekonsiliasi selesai tanpa hitung manual, saldo GL seimbang.
```

5. Lembar Berita Acara Penerimaan (*UAT Sign-Off Form*)

Lembar ini menjadi bukti formal penyelesaian fungsionalitas dan persetujuan peluncuran sistem ke lingkungan produksi.

```
================================================================================
                    BERITA ACARA USER ACCEPTANCE TESTING (UAT)
                       KKUI LOAN SERVICES & MEMBER PORTAL
================================================================================

Pada hari ini, ....................., tanggal ...... bulan ..................... tahun 2027,
telah diselesaikan pengujian User Acceptance Testing (UAT) untuk sistem:

Nama Aplikasi      : KKUI Loan Services & Member Portal
Versi Rilis        : 1.0 (Full Scope - 41 Kelompok Fungsi)
Lingkungan Uji     : Staging Environment Linux VPS (Ubuntu 24.04 LTS)
Pelaksana Pengujian: Tim Pengembang PT Parvata Jingga & Tim Pengurus KKUI

HASIL REKAPITULASI PENGUJIAN:
--------------------------------------------------------------------------------
1. Pengujian Fungsional Anggota (31 Submodul)    : [  ] DITERIMA PENUH   [  ] DENGAN CATATAN
2. Pengujian Fungsional Backoffice (10 Submodul) : [  ] DITERIMA PENUH   [  ] DENGAN CATATAN
3. Pengujian Mesin Scoring Kredit Mandiri        : [  ] DITERIMA PENUH   [  ] DENGAN CATATAN
```

```
4. Pengujian Keamanan Siber & OWASP ASVS Level 2 : [  ] DITERIMA PENUH   [  ] DENGAN CATATAN
5. Pengujian Kinerja & Sizing VPS 300 Anggota    : [  ] DITERIMA PENUH   [  ] DENGAN CATATAN
--------------------------------------------------------------------------------

STATUS DEFECT / TEMUAN KERENTANAN:
• Celah Kritis (Critical Severity) : 0 Terbuka (Nol Celah)
• Celah Tinggi (High Severity)     : 0 Terbuka (Nol Celah)
• Defect Minor / Kosmetik          : ..... Catatan (Ditutup dalam masa garansi)

KESIMPULAN & KEPUTUSAN:
Berdasarkan hasil pengujian di atas, sistem dinyatakan:
[  ] DITERIMA (GO-LIVE PRODUCTION)
[  ] DITERIMA BERSYARAT
[  ] DITOLAK / PERLU PERBAIKAN ULANG

Catatan Tambahan:
.....
.....

PIHAK PENGEMBANG (PT PARVATA JINGGA)       PIHAK PENGGUNA (KOPERASI KKUI)


( Fahmy )                                  ( Avhan HB )
Lead Fullstack Developer                   Product Owner & Scrum Master


( Fadhi W )                                ( ..................................... )
Cyber Security & DevSecOps Lead            Ketua Koperasi Karyawan KKUI
================================================================================
```

Rencana Eksekusi Harian Sprint 1

KKUI Loan Services & Member Portal

Sprint 1 Technical Task Breakdown, Day-to-Day Engineering Schedule (9–20 November 2026), Work-in-Progress (WIP) Limits, and Definition of Done (DoD) Verification

Informasi Sprint 1

- **Nama Proyek:** KKUI Loan Services & Member Portal
- **Periode Sprint 1:** 9 November 2026 s/d 20 November 2026 (10 Hari Kerja)
- **Sprint Goal:** Membangun fondasi keamanan native (Argon2id & MFA TOTP RFC 6238), RBAC Backoffice yang aman, pendaftaran mandiri dengan upload berkas terenkripsi, antrean verifikasi KYC internal dengan AML screening, dan setup automated DevSecOps CI/CD pipeline pada Linux VPS Ubuntu 24.04 LTS.
- **Target Velocity:** 15 Story Points (US-01: 5 SP, US-02: 5 SP, US-03: 5 SP)
- **Alokasi Tim Pengembang:**
- **Product Owner & Scrum Master:** Avhan HB (KKUI)
- **Lead Fullstack Developer:** Fahmy (PT Parvata Jingga) — Fokus: Frontend Next.js, Auth UI, MFA Client, KYC Reviewer UI
- **Core & Backoffice Fullstack Developer:** Mike (PT Parvata Jingga) — Fokus: Database PostgreSQL, Backend Node.js API, Storage Vault, CIF Generator
- **Cyber Security & DevSecOps Lead:** Fadhi W (PT Parvata Jingga) — Fokus: Hardening VPS, CI/CD Pipeline, SAST/DAST, Security Review

1. Rincian Pembagian Tugas Harian (Day-to-Day Schedule)

Minggu Pertama: Pondasi Database, Server Hardening & Core Auth (9–13 November 2026)

Hari 1: Senin, 9 November 2026 (Sprint Planning & Scaffolding)

- **Avhan HB (PO/SM):** Memfasilitasi Sprint Planning (09.00–11.00 WIB), mengunci kriteria penerimaan US-01 s/d US-03, dan memverifikasi ketersediaan aset desain.
- **Fahmy (Lead Fullstack):** Inisiasi proyek Next.js 19 TypeScript, konfigurasi Tailwind CSS dengan token KKUI Design System (Deep Emerald `#003527`, Mint Accent `#31c98f`), dan setup layout dasar responsif.
- **Mike (Core Developer):** Inisiasi backend Node.js Fastify/Express, konfigurasi koneksi pool PostgreSQL 16 & Redis 7, dan penulisan skrip migrasi awal tabel `users`, `roles_permissions`, dan `audit_logs`.
- **Fadhi W (SecOps):** Provisioning Single Linux VPS Ubuntu 24.04 LTS, konfigurasi SSH hardening (Port 2222, SSH Key-only, nonaktifkan root login), dan inisiasi firewall UFW dasar.

Hari 2: Selasa, 10 November 2026 (Database Migration & Server Hardening)

- **Fahmy:** Pembuatan komponen UI atomik: input form validasi Zod, alert modal, button state loading, dan navbar/footer portal anggota.
- **Mike:** Eksekusi skrip migrasi database tabel `member_cifs` dengan kolom `nik_encrypted BYTEA`, pembuatan trigger database PostgreSQL untuk Immutability tabel `audit_logs` (WORM).
- **Fadhi W:** Konfigurasi Fail2ban untuk proteksi brute force SSH & HTTP, pengetatan hak akses direktori vault (`chmod 700 /var/storage/kkui/vault/`), dan integrasi SSL Let's Encrypt TLS 1.3 pada Nginx.
- **Daily Stand-up (09.15 WIB):** Evaluasi progres koneksi database dan akses server staging.

Hari 3: Rabu, 11 November 2026 (Native Auth Engine & Storage Vault)

- **Fahmy:** Pembuatan antarmuka pendaftaran anggota (`/register`): form input email, WhatsApp, NIK, dan multi-dropzone upload dokumen (KTP, Slip Gaji, ID Card) dengan kompresi gambar sisi klien.
- **Mike:** Implementasi service hashing password adaptif **Argon2id**, service upload dokumen ke direktori vault privat, dan modul enkripsi simetris **AES-256-GCM** untuk penyimpanan NIK.
- **Fadhi W:** Setup pipeline CI/CD GitHub Actions: integrasi scanner rahasia **TruffleHog** dan static code analysis **Semgrep (OWASP Top 10 ruleset)**.

- **Daily Stand-up (09.15 WIB):** Koordinasi kontrak payload API registrasi antara Fahmy dan Mike.

Hari 4: Kamis, 12 November 2026 (OTP Verification & Rate Limiting)

- **Fahmy:** Pembuatan UI verifikasi token OTP email (input 6 digit box otomatis fokus) dan integrasi countdown timer 5 menit dengan tombol kirim ulang.
- **Mike:** Pembuatan controller endpoint `POST /api/v1/auth/register` dan `POST /api/v1/auth/verify-otp`, integrasi generator token OTP 6 digit di Redis dengan TTL 300 detik.
- **Fadhi W:** Konfigurasi Redis sliding-window rate limiter pada rute autentikasi (maksimal 10 request/menit per IP) dan penulisan rule Nginx security headers (CSP, HSTS).
- **Daily Stand-up (09.15 WIB):** Uji coba pengiriman email OTP dan validasi batas masa aktif token.

Hari 5: Jumat, 13 November 2026 (Login Kredensial & Proteksi Brute-Force)

- **Fahmy:** Pembuatan antarmuka halaman login mandiri (`/login`) lengkap dengan penanganan status akun terkunci (tampilan modal countdown 15 menit).
- **Mike:** Implementasi endpoint `POST /api/v1/auth/login`, logika deteksi kegagalan login berturut-turut (jika gagal 3x, set `locked_until = NOW() + 15 MIN` di DB), dan penerbitan temporary token untuk MFA.
- **Fadhi W:** Penetration test internal simulasi serangan brute force login (verifikasi akun terkunci tepat pada percobaan ke-3 dan log audit tercatat).
- **Review Internal Akhir Pekan:** Evaluasi kelengkapan fitur US-01 (Pendaftaran Mandiri & Upload Berkas).

Minggu Kedua: MFA TOTP, RBAC Backoffice, & KYC Queue (16–20 November 2026)

Hari 6: Senin, 16 November 2026 (MFA TOTP RFC 6238 Engine)

- **Fahmy:** Pembuatan antarmuka enrolment MFA TOTP (tampilan QR Code rahasia untuk Google Authenticator dan tampilan 8 kode cadangan darurat / backup codes).
- **Mike:** Implementasi library *speakeasy / otplib* untuk pembuatan secret TOTP, enkripsi secret di DB, dan verifikasi endpoint `POST /api/v1/auth/mfa/verify`.
- **Fadhi W:** Audit implementasi cookie sesi JWT: memastikan flag `HttpOnly`, `Secure`, dan `SameSite=Strict` terpasang dengan benar pada response header login.
- **Daily Stand-up (09.15 WIB):** Sinkronisasi alur verifikasi dua langkah antara web frontend dan backend.

Hari 7: Selasa, 17 November 2026 (RBAC Engine & Dynamic Sidebar)

- **Fahmy:** Pembuatan dashboard Backoffice (`/backoffice/dashboard`) dengan sidebar navigasi dinamis yang memfilter menu otomatis sesuai role pengguna (`ADMIN_FRONTDESK`, `MANAGER`, `TREASURER`, `CHAIRMAN`, `SUPERADMIN`).
- **Mike:** Pembuatan middleware RBAC server-side (`requireRole(['ADMIN_FRONTDESK', 'MANAGER'])`), penegakan prinsip *Least Privilege*, dan logging otomatis aksi ke `audit_logs`.
- **Fadhi W:** Uji coba eksploitasi eskalasi wewenang (memastikan token role `MEMBER` ditolak mutlak `403 Forbidden` saat menembak rute backoffice).
- **Daily Stand-up (09.15 WIB):** Pengecekan stabilitas middleware otorisasi.

Hari 8: Rabu, 18 November 2026 (Antrean KYC & Temporary Secure Viewer)

- **Fahmy:** Pembuatan UI antrean verifikasi pendaftaran (`/backoffice/kyc/queue`), tabel data pendaftar baru, filter status, dan tombol aksi detail review.
- **Mike:** Pembuatan endpoint `GET /api/v1/backoffice/kyc/queue` dan service generator **Presigned URL berumur 5 menit** untuk membuka gambar KTP/slip gaji secara aman.
- **Fadhi W:** Setup DAST Baseline Scan otomatis menggunakan **OWASP ZAP** pada container staging VPS.
- **Backlog Refinement (14.00 WIB):** Bersama Avhan HB meninjau backlog Sprint 2 (Simpanan & Kredit Barang Jasa).

Hari 9: Kamis, 19 November 2026 (Persetujuan KYC, AML Screening & Auto-CIF)

- **Fahmy:** Pembuatan modal detail verifikasi berkas: preview dokumen KTP/slip gaji, indikator hasil screening AML/PEP (Clear / Flagged), serta panel input keputusan (Setujui / Tolak dengan catatan).
- **Mike:** Implementasi logika persetujuan bertingkat (Admin Frontdesk $\rightarrow$ Manajer), integrasi pengecekan database lokal AML/PEP, dan mesin pembuat nomor CIF otomatis (`CIF-YYYYMM-XXXX`) serta akun simpanan pokok pasca approval.
- **Fadhi W:** Audit menyeluruh integritas data tabel `audit_logs` (memastikan event approval KYC dan penciptaan CIF terekam lengkap tanpa celah manipulasi).
- **Daily Stand-up (09.15 WIB):** Uji alur pendaftaran dari registrasi anggota hingga nomor CIF terbit.

Hari 10: Jumat, 20 November 2026 (Testing, Sprint Review & Retrospective)

- **09.00 – 12.00 WIB (Freeze Code & Automated Regression Testing):**
- Fahmy & Mike menjalankan test suite otomatis (Unit test & Integration test) dengan target coverage minimal 80%.
- Fadhi W merilis *Security Verification Report Sprint 1* (Zero Critical/High Vulnerabilities).
- **14.00 – 15.30 WIB (Sprint Review bersama Avhan HB & Stakeholder KKUI):**
- Demo live pendaftaran mandiri anggota di lingkungan staging VPS.
- Demo login native dengan proteksi brute force dan autentikasi MFA TOTP.
- Demo antrean review dokumen KTP oleh Admin Frontdesk dan penerbitan nomor CIF otomatis.
- Avhan HB memverifikasi kriteria penerimaan dan memberikan persetujuan sign-off Sprint 1.
- **16.00 – 17.00 WIB (Sprint Retrospective Tim Teknis):**
- Evaluasi proses kerja (Start, Stop, Continue) untuk meningkatkan efisiensi di Sprint 2.

2. Matriks Pembagian Tugas & Batasan WIP (Work-in-Progress)

Untuk mencegah kemacetan kerja pada tim ramping (3 developer), batas WIP dikunci maksimal **2 tiket in-progress per orang** secara bersamaan:

No	Tiket Task ID	Deskripsi Pekerjaan	Penanggung Jawab	Estimasi Jam	Story Terkait	Kriteria Selesai (DoD)
1	`TASK-S1-01`	Setup Next.js, Tailwind Design System & Layout	Fahmy	8 jam	US-01	UI scaffold siap, responsif HP/desktop
2	`TASK-S1-02`	Form Registrasi Anggota & Upload Berkas Client	Fahmy	14 jam	US-01	Validasi Zod aktif, upload maks 3 MB
3	`TASK-S1-03`	UI Verifikasi OTP Email & Countdown Timer	Fahmy	8 jam	US-01	Input 6 digit otomatis submit
4	`TASK-S1-04`	UI Login Mandiri & Penanganan Akun Terkunci	Fahmy	8 jam	US-02	Form login & alert brute force aktif
5	`TASK-S1-05`	UI Enrolment & Verifikasi MFA TOTP Authenticator	Fahmy	12 jam	US-02	QR Code ter-render, input token valid
6	`TASK-S1-06`	Dashboard Backoffice, Dynamic Sidebar & Role UI	Fahmy	10 jam	US-02	Menu tersaring otomatis per role
7	`TASK-S1-07`	UI Antrean KYC & Temporary Document Viewer Modal	Fahmy	14 jam	US-03	Preview KTP presigned URL 5 menit aktif
8	`TASK-S1-08`	Skema PostgreSQL, Migrasi Tabel & Trigger WORM	Mike	12 jam	US-01, 02	Tabel users, cif, audit terbuat di DB
9	`TASK-S1-09`	Service Hashing Password Argon2id & Lockout 3x	Mike	10 jam	US-02	Hash password aman, login lock 15 mnt
10	`TASK-S1-10`	Service Storage Vault Privat & Enkripsi AES-256	Mike	14 jam	US-01	Berkas di luar webroot, NIK terenkripsi
11	`TASK-S1-11`	Endpoint Registrasi & Generator OTP Email Redis	Mike	12 jam	US-01	Token OTP terkirim, masa aktif 5 mnt
12	`TASK-S1-12`	Endpoint MFA TOTP & Refresh Token Rotation	Mike	12 jam	US-02	Cookie HttpOnly Secure terpasang
13	`TASK-S1-13`	Middleware RBAC Server-Side & Logging Audit	Mike	10 jam	US-02	Proteksi rute backoffice, log terekam
14	`TASK-S1-14`	Endpoint Antrean KYC, Screening AML & Auto-CIF	Mike	14 jam	US-03	Approval menerbitkan CIF & rekening
15	`TASK-S1-15`	Provisioning Linux VPS, SSH Key & UFW Firewall	Fadhi W	12 jam	Enabler	Port 2222 aktif, port Postgres tertutup

No	Tiket Task ID	Deskripsi Pekerjaan	Penanggung Jawab	Estimasi Jam	Story Terkait	Kriteria Selesai (DoD)
16	`TASK-S1-16`	Konfigurasi Nginx TLS 1.3, Rate Limiter & Headers	Fadhi W	10 jam	Enabler	CSP & HSTS aktif, SSL Grade A
17	`TASK-S1-17`	Setup Pipeline GitHub Actions (Semgrep, Trivy)	Fadhi W	14 jam	Enabler	CI/CD otomatis berjalan di setiap PR
18	`TASK-S1-18`	Penetration Testing Brute Force, IDOR & DAST ZAP	Fadhi W	16 jam	US-01, 02, 03	Laporan keamanan: 0 Critical/High Vuln

3. Checklist Kesiapan Demo Sprint Review (Sign-Off Gate)

Sebelum sesi Sprint Review pada hari Jumat, 20 November 2026 pukul 14.00 WIB, daftar periksa berikut wajib dipenuhi:

- [ ] Lingkungan Staging VPS (`staging-portal.kkui.co.id`) aktif dan dapat diakses publik via HTTPS TLS 1.3.
- [ ] Tersedia minimal 3 akun uji coba dengan role berbeda (`MEMBER` , `ADMIN_FRONTDESK` , `MANAGER`).
- [ ] Fitur pendaftaran mandiri berhasil mengunggah berkas uji coba KTP dan mengirimkan email OTP riil.
- [ ] Fitur login berhasil meminta token TOTP dari aplikasi Google Authenticator di smartphone.
- [ ] Simulasi salah password 3 kali terbukti mengunci akun selama 15 menit.
- [ ] Antrean KYC Backoffice berhasil menampilkan berkas KTP anggota via presigned URL dan tombol *Approve* berhasil mengenerate nomor CIF resmi.
- [ ] Seluruh unit test lulus dengan cakupan (*code coverage*) $\ge$ 80%.
- [ ] Laporan pengujian keamanan ditandatangani oleh **Fadhi W** menyatakan nol kerentanan berstatus *Critical* atau *High*.

SOP Operasional Server, Backup/DR & Panduan Administrasi

KKUI Loan Services & Member Portal

Deployment Runbook (Ubuntu 24.04 LTS), Disaster Recovery Plan (RTO ≤ 4 Jam / RPO ≤ 24 Jam), System Monitoring Cadence, and Backoffice Admin Operational Manual

---

Informasi Dokumen

- **Nama Sistem:** KKUI Loan Services & Member Portal
- **Penanggung Jawab Teknis:** Fadhi W (Lead DevSecOps) & Mike (Core Developer)
- **Penanggung Jawab Operasional:** Avhan HB (Product Owner & Manajemen Koperasi)
- **Lead Fullstack Developer:** Fahmy (PT Parvata Jingga)
- **Status Dokumen:** Baseline Operations Manual Version 1.0
- **Tanggal Berlaku:** 7 November 2026
- **Infrastruktur Target:** Single Linux VPS Ubuntu 24.04 LTS (4 vCPU / 8 GB RAM / 100–150 GB NVMe / 300 Anggota)
- **Standar Kepatuhan:** ISO/IEC 27001:2022 (A.8.12, A.8.13, A.8.14, A.8.15), OWASP ASVS v4.0

---

1. Deployment & Provisioning Runbook (Step-by-Step CLI)

Panduan instalasi dan deployment pada server VPS Linux baru (*Fresh Install Ubuntu 24.04 LTS*).

1.1 Inisialisasi Sistem & Pembuatan User Non-Root

Lakukan koneksi awal sebagai root lalu buat user khusus pengelola:

```
 # Update repository & upgrade paket sistem
apt update && apt upgrade -y

# Buat user pengelola devops
adduser devops-kkui
usermod -aG sudo devops-kkui

# Setup SSH Key untuk user baru
mkdir -p /home/devops-kkui/.ssh
cp /root/.ssh/authorized_keys /home/devops-kkui/.ssh/
chown -R devops-kkui:devops-kkui /home/devops-kkui/.ssh
chmod 700 /home/devops-kkui/.ssh
chmod 600 /home/devops-kkui/.ssh/authorized_keys

# Login ulang sebagai devops-kkui
exit
```

1.2 Instalasi Dependensi Runtime & Database

Jalankan perintah instalasi runtime lingkungan produksi:

```
 # 1. Install paket pendukung
sudo apt install -y curl wget git gnupg lsb-release ufw fail2ban jq

# 2. Install Node.js 20 LTS (NodeSource)
curl -fsSL https://deb.nodesource.com/setup_20.x | sudo -E bash -
sudo apt install -y nodejs
sudo npm install -g pm2

# 3. Install PostgreSQL 16
sudo sh -c 'echo "deb http://apt.postgresql.org/pub/repos/apt $(lsb_release -cs)-pgdg main" > /etc/apt/sources.list.d/pgdg.li
st'
wget --quiet -O - https://www.postgresql.org/media/keys/ACCC4CF8.asc | sudo apt-key add -
sudo apt update && sudo apt install -y postgresql-16 postgresql-contrib-16

# 4. Install Redis 7
sudo apt install -y redis-server

# 5. Install Nginx & Certbot SSL
sudo apt install -y nginx certbot python3-certbot-nginx
```

1.3 Konfigurasi Basis Data PostgreSQL & Redis

```
# Inisialisasi Database & User PostgreSQL
sudo -u postgres psql << EOF
CREATE DATABASE kkui_core_prod;
CREATE USER kkui_dbuser WITH ENCRYPTED PASSWORD 'StrongSecretPasswordDB#2026';
GRANT ALL PRIVILEGES ON DATABASE kkui_core_prod TO kkui_dbuser;
\c kkui_core_prod
CREATE EXTENSION IF NOT EXISTS "pgcrypto";
EOF

# Konfigurasi Keamanan Redis
# Edit /etc/redis/redis.conf:
# - bind 127.0.0.1
# - requirepass StrongRedisPassword#2026
# - rename-command FLUSHALL ""
# - rename-command CONFIG ""
sudo systemctl restart redis-server
```

1.4 Konfigurasi Direktori Penyimpanan Vault Berkas (KTP/Slip Gaji)

```
sudo mkdir -p /var/storage/kkui/vault
sudo chown -R devops-kkui:devops-kkui /var/storage/kkui/vault
sudo chmod 700 /var/storage/kkui/vault
```

1.5 Prosedur Rilis Aplikasi (*Zero-Downtime Deployment*)

Alur rilis versi baru menggunakan PM2 Cluster Mode:

```
cd /var/www/kkui-portal

# 1. Pull kode terbaru dari branch main
git pull origin main

# 2. Install dependensi & compile TypeScript
npm ci --production
npm run build

# 3. Eksekusi skrip migrasi database (jika ada)
npm run db:migrate

# 4. Reload proses PM2 tanpa memutus koneksi pengguna aktif (Zero-Downtime)
pm2 reload ecosystem.config.js --update-env

# 5. Verifikasi status proses & log
pm2 status
pm2 logs --lines 50
```

---

2. Standard Operating Procedure (SOP) Backup & Disaster Recovery (DRP)

Sistem menjamin batas toleransi pemulihan bencana: * **Recovery Point Objective (RPO) $\le$ 24 Jam:** Data transaksi yang hilang maksimal adalah transaksi dalam siklus 1 hari terakhir. * **Recovery Time Objective (RTO) $\le$ 4 Jam:** Sistem kembali aktif melayani pengguna maksimal dalam 4 jam pasca kegagalan fisik server.

2.1 Skrip Otomasi Backup Harian (*Cron Daily Backup*)

Skrip `/usr/local/bin/kkui-backup.sh` dieksekusi otomatis setiap hari pukul **02.00 WIB**:

```
#!/bin/bash
set -e

BACKUP_DIR="/var/backups/kkui"
DATE=$(date +%Y%m%d_%H%M%S)
RETENTION_DAYS=30
PASSPHRASE="EnkripsiKMSBackupKoperasiKKUI#2026"

mkdir -p $BACKUP_DIR

echo "[$(date)] Memulai pencadangan database PostgreSQL..."
# Dump database dengan kompresi gzip
PGPASSWORD="StrongSecretPasswordDB#2026" pg_dump -U kkui_dbuser -h 127.0.0.1 kkui_core_prod | gzip > "$BACKUP_DIR/db_kkui_$DA
TE.sql.gz"

echo "[$(date)] Mengenkripsi arsip cadangan dengan GPG (AES-256)..."
# Enkripsi file backup
gpg --batch --yes --passphrase "$PASSPHRASE" --symmetric --cipher-algo AES256 "$BACKUP_DIR/db_kkui_$DATE.sql.gz"
rm -f "$BACKUP_DIR/db_kkui_$DATE.sql.gz"
```

```
echo "[$(date)] Mengunggah cadangan terenkripsi ke Cloud Storage Offsite (S3/GCS)..."
# Mengirim ke offsite storage terpisah (misal AWS S3 / Wasabi / Backblaze)
# aws s3 cp "$BACKUP_DIR/db_kkui_$DATE.sql.gz.gpg" s3://kkui-offsite-backup-vault/

echo "[$(date)] Membersihkan file cadangan lokal yang lebih lama dari $RETENTION_DAYS hari..."
find $BACKUP_DIR -type f -name "*.gpg" -mtime +$RETENTION_DAYS -delete

echo "[$(date)] Pencadangan harian selesai dengan sukses."
```

Pasang pada Crontab sistem (`crontab -e`):

```
0 2 * * * /usr/local/bin/kkui-backup.sh >> /var/log/kkui-backup.log 2>&1
```

2.2 Panduan Pemulihan Bencana (*Disaster Recovery Playbook*)

Jika server utama VPS mengalami crash fatal atau kerusakan hardware:

```
[ LANGKAH 1: PROVISIONING SERVER BARU ] (Target Waktu: 45 Menit)
  • Buka instance baru di penyedia cloud (Ubuntu 24.04 LTS, 4 vCPU, 8 GB RAM).
  • Jalankan playbook deployment (Bagian 1 runbook ini).

[ LANGKAH 2: PENGAMBILAN ARSIP CADANGAN OFFSITE ] (Target Waktu: 30 Menit)
  • Unduh file snapshot cadangan terakhir dari storage offsite:
    aws s3 cp s3://kkui-offsite-backup-vault/db_kkui_LATEST.sql.gz.gpg /tmp/

[ LANGKAH 3: DEKRIPSI & RESTORE BASIS DATA ] (Target Waktu: 45 Menit)
  • Dekripsi arsip:
    gpg --batch --yes --passphrase "$PASSPHRASE" --decrypt /tmp/db_kkui_LATEST.sql.gz.gpg > /tmp/db_kkui_restore.sql.gz
  • Restore ke PostgreSQL:
    gunzip -c /tmp/db_kkui_restore.sql.gz | psql -U kkui_dbuser -h 127.0.0.1 -d kkui_core_prod

[ LANGKAH 4: VALIDASI INTEGRITAS DATA ] (Target Waktu: 30 Menit)
  • Verifikasi integritas tabel:
    SELECT COUNT(*) FROM users;
    SELECT COUNT(*) FROM loans;
    SELECT COUNT(*) FROM savings_accounts;
  • Verifikasi konsistensi buku besar: Cek saldo GL vs total saldo simpanan anggota.

[ LANGKAH 5: PENGALIHAN DNS DOMAIN ] (Target Waktu: 30 Menit)
  • Update A Record domain `portal.kkui.co.id` pada dashboard Cloudflare ke IP server baru.
  • Terbitkan sertifikat SSL Let's Encrypt baru: `sudo certbot --nginx -d portal.kkui.co.id`
  • Pengujian login fungsional dan serah terima ke tim operasional.
```

---

3. Ritme Operasional & Pemantauan Sistem (Monitoring Cadence)

Berdasarkan standar ISO 27001, tim DevSecOps (**Fadhi W**) dan Developer (**Mike**) mematuhi jadwal pemeliharaan berkala:

Frekuensi	Aktivitas Pemeliharaan & Audit	Parameter / Indikator yang Diperiksa	Penanggung Jawab
Harian	• Pemeriksaan Log Cadangan Database • Pengecekan Alert Ambang Batas Resource • Monitoring Saldo Buffer API Bank	• Status exit code skrip backup harian (`0 = Sukses`). • Utilisasi CPU & RAM (harus < 70%). • Saldo buffer rekening bank $\ge$ Rp15.000.000.	Fadhi W & Bendahara
Mingguan	• Pemeriksaan Log Fail2ban & WAF • Analisis Error Log Nginx & PM2 • Rotasi Log Sistem (Logrotate)	• Daftar IP yang terblokir karena percobaan brute force. • Frekuensi error HTTP 500 / 502 pada backend API. • Kapasitas sisa ruang penyimpanan NVMe (< 65%).	Fadhi W & Mike
Bulanan	• Patching OS & Dependency Security Update • Simulasi Restore Database Uji Coba • Audit Akun Staf Non-Aktif	• Instalasi patch keamanan kernel Ubuntu via `apt update` . • Verifikasi integritas file backup dapat di-restore di staging. • Penonaktifan akun pegawai yang mutasi/keluar.	Fadhi W
Per Rilis	• Pemindaian SAST (Semgrep) & DAST (ZAP) • Review Kepatuhan Audit Log WORM • UAT Sign-Off bersama PO	• Nol kerentanan kategori *Critical* atau *High*. • Verifikasi pencatatan audit log transaksi finansial. • Persetujuan formal Berita Acara UAT oleh Avhan HB.	Fadhi W, Fahmy, Avhan HB

---

4. Panduan Administrasi Backoffice (Operational Manual)

Panduan praktis operasional harian bagi staf backoffice koperasi:

4.1 Panduan untuk Admin Frontdesk (Verifikasi KYC & Anggota)

1. **Membuka Antrean Pendaftaran:**
2. Buka menu **CIF & Membership** $\rightarrow$ pilih submenu **Antrean Verifikasi KYC**.
3. Klik tombol **Detail** pada calon anggota berstatus `Pending Verification`.
4. **Memverifikasi Berkas:**
5. Periksa kesesuaian nama lengkap dan 16 digit NIK antara isian form dengan foto KTP asli.
6. Periksa Kartu Pegawai dan Slip Gaji untuk memvalidasi departemen serta penghasilan riil.
7. Perhatikan indikator **Screening AML/PEP**: Jika berstatus *Flagged*, segera laporkan ke Manajer Operasional; jika *Clear*, lanjutkan verifikasi.
8. **Mengambil Keputusan:**
9. Jika dokumen valid: Klik tombol **Setujui Verifikasi Tahap 1**.
10. Jika dokumen buram/salah: Klik tombol **Tolak dengan Catatan**, pilih alasan (misal: *Foto KTP tidak terbaca*), sistem akan otomatis mengirim notifikasi email ke anggota untuk mengunggah ulang.

4.2 Panduan untuk Manajer Operasional (Persetujuan Kredit LOS)

1. **Membuka SLA Task Inbox:**
2. Masuk ke menu **LOS Approval Center** $\rightarrow$ periksa tab antrean berdasarkan warna SLA (Hijau: Aman, Kuning: Mendekati 24 Jam, Merah: Overdue).
3. **Evaluasi Scoring Mandiri & Rasio Utang:**
4. Buka tiket pengajuan kredit debitur.
5. Periksa **Panel Scoring Kredit Mandiri**:
   - Periksa nilai **Debt Service Ratio (DSR)**: Apakah di bawah batas aman 33% atau berada di rentang 33%–50%.
   - Periksa **Grade Skor Kredit Internal** (A / B / C / D).
6. **Eksekusi Keputusan:**
7. **Approve:** Klik Setujui jika memenuhi syarat kelayakan (tiket berlanjut ke penandatanganan akad e-Sign anggota).
8. **Adjustment:** Jika rasio utang berisiko, manajer dapat memilih opsi penyesuaian (menurunkan plafon kredit, memperpanjang tenor angsuran, atau mewajibkan DP tambahan).
9. **Reject:** Menolak permohonan dengan mencantumkan alasan formal pada sistem.

4.3 Panduan untuk Bendahara Treasury (Pencairan Kas & Payroll PR23)

1. **Pencairan Dana Pinjaman (Disbursement API):**
2. Masuk ke menu **Treasury Operations** $\rightarrow$ pilih **Antrean Pencairan Pinjaman**.
3. Pastikan tiket pinjaman telah berstatus `WAITING_DISBURSEMENT` (telah ditandatangani e-Sign oleh debitur).
4. Periksa ketersediaan **Saldo Buffer Bank**: Jika saldo buffer kurang dari total pencairan, lakukan transfer top-up ke rekening penampung bank terlebih dahulu.
5. Jika nominal pinjaman **> Rp25.000.000**: Sistem akan meminta input **Token Otorisasi Ganda (Dual Control)** yang diterbitkan oleh Ketua Koperasi.
6. Klik tombol **Eksekusi Transfer API**. Dalam hitungan detik, sistem akan mencairkan dana ke rekening bank debitur dan meng-update jurnal kas Buku Besar (GL).
7. **Eksekusi Rekonsiliasi Payroll PR23 (Akhir Bulan):**
8. **Langkah A (Generate Tagihan):** Pada tanggal cut-off (misal tanggal 25), buka menu **Payroll PR23** $\rightarrow$ klik **Generate File Cut-Off Tagihan** $\rightarrow$ unduh file CSV/Excel untuk diserahkan ke bagian HRD perusahaan.
9. **Langkah B (Upload Realisasi Gaji):** Setelah HRD selesai memproses penggajian, unduh file laporan hasil potongan gaji riil dari HRD $\rightarrow$ klik **Upload File Hasil Potongan Payroll** pada portal KKUI.
10. **Langkah C (Auto-Matching & Jurnal):** Klik **Jalankan Rekonsiliasi Otomatis**. Sistem akan mencocokkan data baris per baris. Transaksi sukses otomatis melunasi angsuran pinjaman; potongan gagal otomatis dicatat sebagai tunggakan (*arrears*) untuk diperhitungkan dendanya pada proses EOD batch.